CASE STUDY

The Year 2023 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

For the people who defend networks, 2023 was the year the edge gave way. A file-transfer product was hit with a zero-day in January and another over the US Memorial Day weekend; an email security appliance turned out to have been exploited since October 2022, and its maker told customers to replace compromised appliances whatever their patch level; Citrix, Ivanti, Cisco, Atlassian and JetBrains products were exploited as zero-days or soon after their fixes. The second story was identity. An acquired signing key let one actor forge tokens and read government mail in the cloud, a stolen session from a patched appliance still worked after the patch, a support system exposed files, some holding session tokens, that customers had uploaded, and a casino company disclosed an intrusion that began with social engineering of its outsourced IT support vendor. Behind both stories sat the money: ransomware payments passed a billion dollars by one vendor's estimate, CISA and the FBI published joint ransomware advisories from February to December, and police took down Hive, Genesis Market, QakBot and Ragnar Locker and struck at ALPHV. Governments answered with a national strategy that moved liability toward software makers, an SEC rule that put material cyber incidents on Form 8-K, an executive order on AI, and a joint pledge by 50 members of the Counter Ransomware Initiative that their national governments should not pay.

This study is the dated record of that year. It is a chronicle, not a deep dive: where another study in this series is the home for an event, this one gives a paragraph and a link. The MOVEit campaign and Cl0p's file-transfer playbook are told in the Cl0p file-transfer study; Sandworm's grid attack, disclosed in 2023, in the Sandworm study; the wider records of the state actors in the China-attributed, Russia-attributed, North Korea-attributed and Iran-attributed actor studies; the commercial spyware market in the zero-day market study; and the third year of Log4Shell in the Log4Shell study. Everything else in 2023 that the verified record supports is here, in date order, with the source behind each line.

Evidence grade: the events, attributions, sanctions, rules and laws are **Confirmed** from the government agency, the victim's own statement or SEC filing, the vendor that observed the activity, the CVE, NVD and KEV records, or the MITRE record. Annual estimates from vendor datasets (Chainalysis payments, Mandiant M-Trends, the Verizon DBIR) and the few statements read only through a secondary page are **Reported** and attributed by name. Counts this study computed from the KEV feed and checks it re-ran against the library's ATT&CK, CWE and D3FEND data are **Demonstrated**. Where this study draws its own conclusion or maps behavior to ATT&CK on its own reading, it says **Inferred**.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2023, with lead-in events from late 2022 and later reports and filings that describe 2023
The edge-device year	Zero-days or near zero-days in GoAnywhere MFT (Jan), Barracuda ESG (exploited from Oct 2022), MOVEit Transfer (27 May), NetScaler ADC (Jun), Ivanti EPMM (Apr to Jul), Confluence and Cisco IOS XE (Oct); Citrix Bleed exploited after its 10 Oct fix [4][25][30][44][45][68][62][69]
Most exploited of 2023	AA24-317A's list is led by Citrix CVE-2023-3519 and CVE-2023-4966, Cisco CVE-2023-20198 and CVE-2023-20273, FortiOS CVE-2023-27997 and MOVEit CVE-2023-34362, and still carries Log4Shell and Netlogon [115]
Cloud identity	Storm-0558 forged tokens with an acquired MSA signing key: about 25 organizations per Microsoft, 22 organizations and over 500 individuals per the CSRB [35][39]
Supply chain	3CX, the first software supply chain attack Mandiant had seen lead to another (X_TRADER); JumpCloud; CircleCI; Ledger Connect Kit [17][41][102][83]
Government attributions	Volt Typhoon as PRC state-sponsored (24 May); Snake to a unit of FSB Center 16 (9 May); Star Blizzard as almost certainly subordinate to FSB Centre 18 (7 Dec); the SVR behind TeamCity exploitation (13 Dec); BlackTech as PRC-linked (27 Sep); Kimsuky as subordinate to the RGB (1 Jun, OFAC 30 Nov); CyberAv3ngers as IRGC-affiliated (1 Dec) [28][22][81][82][60][92][93][79]
Ransomware money	Payments over US$1 billion in 2023 (Chainalysis, Reported); IC3 adjusted ransomware losses over US$59.6 million from 2,825 complaints [88][120]
Law enforcement	Hive infrastructure shut down (26 Jan); Genesis Market taken down (5 Apr); QakBot dismantled (25 Aug); Ragnar Locker taken down (16 to 20 Oct); action against ALPHV (early Dec); Trickbot sanctions in February and September [96][98][51][100][85][97][101]
KEV in 2023	187 entries added during the year, 121 of them CVE-2023 ids; 43 now flagged for known ransomware use (computed from catalog version 2026.11.10) [89]
Zero-days	97 exploited in the wild in 2023, up from 62 in 2022 and below 106 in 2021 (Google TAG and Mandiant) [116]
Policy landmarks	NIS2 in force (Jan); US National Cybersecurity Strategy (2 Mar); spyware executive order (27 Mar); Secure by Design (Apr, updated 25 Oct); SEC disclosure rules (26 Jul); CSF 2.0 draft (8 Aug); SEC charges against SolarWinds and its CISO and Executive Order 14110 (30 Oct); Counter Ransomware Initiative statement (1 Nov) [121][122][124][125][46][126][74][127][128]
This study's MITRE binding	123 Enterprise and 12 ICS technique rows, 36 group, software and campaign objects with library pages, 17 CWE rows with the library's CAPEC pairings, 21 D3FEND countermeasures, and two Navigator layers (Part 13)

Key findings

- **The edge was the front door.** Of the six CVEs at the top of AA24-317A's 2023 list, five sit in edge or file-transfer products, and most of the top CVEs of 2023 were first exploited as zero-days (Confirmed [115]; Inferred for the count of edge products). M-Trends puts exploits at 38% of initial infection vectors in its 2023 cases (Reported [118]).

- **Patching did not end an intrusion.** Barracuda told customers to replace compromised appliances whatever their patch level (Confirmed [26]); NetScaler told customers to kill all active and persistent sessions as well as patch (Confirmed [69]); AA23-325A said to assume full admin access and reimage (Confirmed [70]); AA23-347A said to assume compromise on any unpatched TeamCity server (Confirmed [82]).
- **The cloud provider's own key became the target.** Storm-0558 forged tokens with a 2016 consumer signing key that a validation error let it use against enterprise mail; Microsoft does not know how or when the key was taken, and the CSRB called the intrusion one that "should never have happened" (Confirmed [36][39][38]).
- **Logging decided who could see it.** The State Department found Storm-0558 through a mailbox access log it had only because it bought a premium license; some other victims, including Commerce and the UK victims, could not see historical logs (Confirmed [39]). The CSRB asked cloud providers to stop selling security logging as an add-on (Confirmed [39]).
- **Sessions and help desks beat MFA.** Citrix Bleed sessions, HAR files holding session tokens at Okta, a stolen SSO session cookie at CircleCI, and help-desk impersonation by Scattered Spider and ALPHV affiliates each bypassed the second factor rather than breaking it (Confirmed [70][65][102][77][85]; Inferred for the pattern).
- **One supply chain attack fed another.** 3CX's initial compromise came from a tampered X_TRADER installer downloaded from Trading Technologies, and ATT&CK records the campaign as C0057 (Confirmed [17][132]).
- **State actors pre-positioned in critical infrastructure.** Microsoft assessed with moderate confidence that Volt Typhoon was building capability that could disrupt US to Asia communications in a future crisis, living off the land in Guam and the US (Confirmed [29]). IRGC-affiliated actors compromised Unitronics PLCs at US water facilities (Confirmed [79]).
- **Ransomware money hit a record by one estimate, and the official loss count stayed a floor.** Chainalysis estimates payments passed US$1 billion (Reported [88]); IC3 counts adjusted ransomware losses just over US$59.6 million and says its figures are artificially low (Confirmed [120]).
- **Police went after infrastructure.** Hive's servers, Genesis Market, QakBot's botnet and Ragnar Locker's leak site were taken down, and Treasury and the UK sanctioned 18 Trickbot members over the year (Confirmed [96][98][52][100][97][101]).

Top recommendations

1. **Treat every internet-facing appliance as a tier-zero asset with a replacement plan.** Patch KEV entries first, and when an edge device is found exploited, plan to reimage or replace it and rotate every credential it held, as Barracuda, CISA and NetScaler advised (Confirmed [26][70][69][82]).
2. **Revoke sessions, not just passwords.** After an appliance or identity incident, invalidate active sessions and tokens; Citrix Bleed sessions outlived the patch, and the files uploaded to Okta's support system carried live session tokens (Confirmed [69][65]).
3. **Make MFA phishing-resistant and harden the help desk.** AA23-320A asks for FIDO/WebAuthn or PKI-based MFA and allowlisting of remote access software; it has no control written specifically for the help desk, so write one (Confirmed [77]; Inferred for the gap).

4. **Buy, keep and watch the logs that would show you an identity provider's failure.** The State Department caught Storm-0558 with a custom alert on the MailItemsAccessed log; enable the equivalent audit logging and alert on unexpected application ids (Confirmed [37][39]).
5. **Watch for living off the land on domain controllers and edge devices.** AA23-144A asks defenders to harden domain controllers, watch for ntdsutil process creation, limit port proxying, review perimeter firewall changes and forward logs to a hardened central server (Confirmed [28]).
6. **Change default passwords and take PLCs off the internet.** The Unitronics devices were internet-exposed and had a default password or none, which the CISA alert says was likely how the actors got in (Confirmed [78][79]).

Scope and method

This study covers intrusions, exploited vulnerabilities, crime and the government response in calendar year 2023. It draws on CISA, FBI, NSA and partner advisories and alerts, the Cyber Safety Review Board, Treasury, the SEC, the White House archive, NIST, Europol and the European Commission, the victims' own statements and SEC filings (T-Mobile, Fortra, DISH, LastPass, Latitude Financial, 3CX, Western Digital, Barracuda, JumpCloud, CircleCI, Estee Lauder, Clorox, Caesars, MGM Resorts, Johnson Controls, Okta, 23andMe, the British Library, Ledger, Microsoft), the vendors that observed the activity (Microsoft, Mandiant, Cisco and Talos, NetScaler, Kaspersky, Citizen Lab, SektorCERT, Cloudflare, Google, AWS), the CVE, NVD and KEV records, the live MITRE ATT&CK pages and the library's own data files. Every source was opened on 11 November 2026. Quotations are kept to a few words. Tradecraft is described at the level the advisories use, by technique name and id; no exploit details, commands or ransom notes are reproduced.

Grade	Meaning
Confirmed	A primary source was opened: the agency, the victim, the vendor that observed the activity, a CVE, NVD or KEV record, or the MITRE record itself
Reported	Known only through a secondary source or a vendor's estimate from its own dataset, attributed by name, such as a Chainalysis figure or a statement relayed on another party's page
Demonstrated	A reproduction exists: this study re-ran the count or the check against the KEV feed or the library's data files
Inferred	This study's own reasoning from the cited facts, labelled where it appears

How the record is routed:

- **Home studies.** Where another study in this series is the home for an event, this study gives one paragraph and a link. The MOVEit campaign's home is the Cl0p file-transfer study and the Sandworm grid attack's home is the Sandworm study.
- **Attribution language.** Each source's own words are carried through as written, because the strength varies: "PRC state-sponsored" (AA23-144A), "PRC-linked" (AA23-270A), "high confidence" that UNC4841 supports the PRC (Mandiant), "suspected North Korean nexus" for UNC4736 (Mandiant), "almost certainly subordinate" to FSB Centre 18 (AA23-341A), "moderate confidence" for Storm-0558's China base (Microsoft) (Confirmed [28][60][27][17][81][36]; Inferred for the comparison). A vendor's name for a group (Storm-0558, UNC4841, UNC4736, UNC4899, Storm-1359) is used with the vendor's report; its ATT&CK

group is given only where the library's alias table carries the name.

- **Victims who name no actor.** The Caesars and MGM filings name no actor, and AA23-320A does not name either company; tying MGM to ALPHV-BlackCat and Scattered Spider rests on Chainalysis and is graded Reported; no source opened ties Caesars to a named actor (Confirmed [56][57][77]; Reported [88]).
- **Revised advisories.** Several 2023 advisories were revised later: AA23-320A on 29 July 2025, AA23-335A on 18 December 2024, AA23-353A on 27 February 2024, AA23-136A on 20 November 2024, AA23-061A on 13 November 2023 and again in August 2024 (Confirmed [77][79][85][24][11]). Where the live text mixes later behavior into a 2023 advisory, this study says so and does not date the later material to 2023.
- **Cumulative counts.** CISA's LockBit figures run from 2020, Hive's Europol figures from June 2021 and BianLian's from June 2022; they are not 2023-only figures (Confirmed [34][96][24]).
- **KEV dates.** A KEV date-added value is the day CISA listed the CVE, not the day it was first exploited. The known-ransomware flag is revised after listing, so the 43 flags counted here are as of November 2026, not as known in 2023 (Demonstrated [89]).
- **ATT&CK versions.** The 2023 advisories print ATT&CK v13 and v14 ids. This study maps them to v20.0 through the library's `superseded_by.jsonl`; revoked ids are named where they are replaced (Demonstrated [134]).
- **2022 events disclosed in 2023.** The Harmony bridge theft (June 2022), the Sandworm grid attack (October 2022), CircleCI (December 2022) and the start of the Barracuda and Telerik exploitation fell in 2022 but were attributed or reported in 2023; they appear on the date of the 2023 record.
- **What is overstated and what is understated.** This study's own reading of where the 2023 record misleads is set out under Cross-cutting themes, with the evidence for each point.
- **What was not checked.** The following reported events and documents were not opened at a primary source during the research and are left out of the dated record: the DOJ releases on Hive, QakBot, Genesis Market, ALPHV and the Snake disruption, and the operation name used for the Snake takedown; the BreachForums administrator arrest; the Royal Mail, ION Group, Reddit, US Marshals Service, Capita, UK Electoral Commission, Henry Schein, ICBC Financial Services, DP World Australia, Kyivstar, Comcast Xfinity, HCA Healthcare and Toyota incidents; the Wiz figure for the Microsoft storage exposure; the name Anonymous Sudan for Storm-1359; the attribution of the Outlook CVE-2023-23397 exploitation to a named ATT&CK group; Talos's implant counts for Cisco IOS XE; Mandiant's own JumpCloud attribution page beyond the post cited; the EU Cyber Resilience Act's 2023 political agreement date; and the later outcome of the SEC case against SolarWinds. Their absence here is a gap in what was opened, not a judgment on what happened.

Part 1: the year at a glance

One row per dated event or report. Grades and sources are given on each row; later Parts tell the longer stories. "Unnamed" means the verified record names no actor.

Date	Event	Who (as the source names them)	Grade and source
2022-06-24 (theft); 2023-01-23 (statement)	FBI confirms the US$100 million theft from Harmony's Horizon bridge; update on 6 Feb	Lazarus Group (APT38)	Confirmed [5]
2022-10	Earliest evidence of exploitation of Barracuda ESG CVE-2023-2868	UNC4841 (Mandiant, from 10 Oct 2022)	Confirmed [25][27]
2022-10 to 2023-01	Phishing leads victims to legitimate remote monitoring and management software, then used in a refund scam to steal from their bank accounts (AA23-025A, 25 Jan)	Unnamed	Confirmed [1]
2022-10-10 (event); 2023-11-09 (report)	Sandworm causes an outage at a Ukrainian substation through the substation's own MicroSCADA software, then deploys a CaddyWiper variant on 12 Oct	Sandworm	Confirmed [75]
2022-11 to 2023-01	Multiple actors, including an APT actor, exploit Telerik UI CVE-2019-18935 on a federal agency IIS server (AA23-074A)	Multiple actors	Confirmed [3]
2022-11-25 to 2023-01-05	A bad actor pulls data on about 37 million T-Mobile accounts through a single API (8-K, 19 Jan)	Unnamed	Confirmed [2]
2022-12-16 to 2023-01-04	Malware on a CircleCI engineer's laptop steals a 2FA-backed SSO session; customer secrets taken 22 Dec; customers told to rotate all secrets on 4 Jan	Unnamed	Confirmed [102]
2023-01	NIS2 Directive enters into force	EU	Confirmed [121]
2023-01	APT actors inside an aeronautical organization through ManageEngine CVE-2022-47966 and FortiOS CVE-2022-42475 (AA23-250A, 7 Sep)	Nation-state APT actors	Confirmed [54]
2023-01-18 to 01-30	Zero-day RCE CVE-2023-0669 used against GoAnywhere MFT; Fortra learns of it on 30 Jan; KEV on 10 Feb	Cl0p (named in AA23-158A as an earlier campaign)	Confirmed [4][31][89]
2023-01-26	Hive infrastructure shut down by German, Dutch and US authorities with Europol; decryption tools given to victims	Hive	Confirmed [96]

Date	Event	Who (as the source names them)	Grade and source
2023-02-07 to 02-08	CISA releases an ESXiArgs recovery script; AA23-039A says over 3,800 ESXi servers compromised	ESXiArgs actors	Confirmed [7][6]
2023-02-09	AA23-040A: North Korean actors use Maui and H0lyGh0st ransomware against healthcare to fund the state. Treasury and the UK sanction seven Trickbot members	DPRK state-sponsored actors; Trickbot	Confirmed [8][97]
2023-02-23 to 02-27	DISH discloses an outage caused by a cyber-security incident and learns data was extracted (8-K, 28 Feb)	Unnamed (the filing refers to ransomware)	Confirmed [9]
2023-03-01	LastPass describes a two-stage intrusion ending in theft of encrypted customer vault backups	Unnamed	Confirmed [10]
2023-03-02	AA23-061A on Royal ransomware. National Cybersecurity Strategy released	Royal; The White House	Confirmed [11][122]
2023-03	Latitude Financial customers and applicants in Australia and New Zealand have personal information stolen	Unnamed	Confirmed [14]
2023-03-13	CISA's Ransomware Vulnerability Warning Pilot notifies 93 organizations running Exchange vulnerable to ProxyNotShell (the 2022 chronicle)	CISA	Confirmed [123]
2023-03-14	Microsoft patches Outlook CVE-2023-23397, exploited against European government, transport, energy and military targets; KEV the same day	A Russia-based threat actor	Confirmed [12][89]
2023-03-16	AA23-075A on LockBit 3.0	LockBit 3.0 affiliates	Confirmed [13]
2023-03-26	Western Digital identifies unauthorized access to a number of its systems (release 2 Apr)	Unauthorized third party	Confirmed [20]
2023-03-27	Executive order bars US government operational use of risky commercial spyware	The White House	Confirmed [124]
2023-03-30	3CX warns that its Electron Windows app in Update 7 has a security issue; CISA alert the same day	UNC4736 (Mandiant, via 3CX)	Confirmed [15][18]

Date	Event	Who (as the source names them)	Grade and source
2023-04	CISA publishes Secure by Design (updated 25 Oct with 17 partners)	CISA and partners	Confirmed [125]
2023-04 to 2023-07	Zero-day exploitation of Ivanti EPMM CVE-2023-35078 against Norwegian organizations including a government agency	APT actors	Confirmed [45]
2023-04-05	Genesis Market taken down: 119 arrests, 208 searches	Genesis Market	Confirmed [98]
2023-04-18	Joint advisory: APT28 exploited Cisco SNMP CVE-2017-6742 in 2021 and deployed Jaguar Tooth	APT28	Confirmed [90]
2023-04-20	Mandiant traces 3CX to a trojanized X_TRADER installer	UNC4736, linked with moderate confidence to AppleJeus	Confirmed [17]
2023-04 to 05	PaperCut CVE-2023-27350 exploited from mid-April; Bl00dy Ransomware Gang hits education in early May (AA23-131A, 11 May)	Bl00dy Ransomware Gang	Confirmed [21]
2023-05-09	AA23-129A attributes Snake to a known unit of FSB Center 16	Turla	Confirmed [22]
2023-05-11	Coordinated attack on 16 Danish energy companies through Zyxel CVE-2023-28771; second wave from 22 May; 22 companies reached	Unnamed	Confirmed [23]
2023-05-15	Storm-0558 begins accessing email with forged tokens	Storm-0558 (China-based, Microsoft)	Confirmed [35][36]
2023-05-16	Treasury designates Mikhail Matveev; indictments unsealed; reward up to US$10 million	Matveev (Hive, LockBit, Babuk)	Confirmed [99]
2023-05	AA23-136A on BianLian	BianLian	Confirmed [24]
2023-05-19 to 05-21	Barracuda identifies CVE-2023-2868 and patches all ESG appliances	UNC4841	Confirmed [26]
2023-05-24	AA23-144A and Microsoft's report on Volt Typhoon	Volt Typhoon (PRC state-sponsored)	Confirmed [28][29]
2023-05-27	MOVEit Transfer CVE-2023-34362 first exploited; Progress announces 31 May; KEV 2 Jun	CL0P (TA505)	Confirmed [30][31][104]

Date	Event	Who (as the source names them)	Grade and source
2023-05-31 and 06-06	Barracuda says compromised appliances must be replaced regardless of patch level	n/a	Confirmed [26]
2023-06-01	Kaspersky discloses Operation Triangulation. Joint advisory on Kimsuky spearphishing	Unnamed; Kimsuky	Confirmed [32][92]
2023-06	Citrix CVE-2023-3519 exploited as a zero-day against a critical infrastructure organization (AA23-201A, 20 Jul). ColdFusion CVE-2023-26360 used against two federal agency systems (AA23-339A, 5 Dec)	Unnamed actors	Confirmed [44][80]
2023-06	Layer 7 DDoS surges temporarily affect some Microsoft services	Storm-1359	Confirmed [33]
2023-06-07	AA23-158A on CL0P and MOVEit	CL0P (TA505)	Confirmed [31]
2023-06-13	Mandiant reports UNC3886's VMware Tools zero-day CVE-2023-20867. KEV lists FortiOS CVE-2023-27997	UNC3886	Confirmed [91][89]
2023-06-14	AA23-165A on LockBit	LockBit	Confirmed [34]
2023-06-15 to 06-16	State Department detects the Storm-0558 intrusion and contacts Microsoft. Mandiant's UNC4841 report	Storm-0558; UNC4841	Confirmed [39][27]
2023-06-22 to 07-05	JumpCloud spear-phished; first customer impact 5 Jul; admin API keys rotated	Nation-state actor (JumpCloud); UNC4899 (Mandiant)	Confirmed [42][41]
2023-06-22 to 06-24	Wiz reports an overly permissive SAS token in a public Microsoft GitHub repository; revoked 24 Jun	n/a	Confirmed [58]
2023-06-29	Microsoft revokes all MSA signing keys	Microsoft	Confirmed [36]
2023-07-06	AA23-187A on Truebot	Truebot operators	Confirmed [40]
2023-07-11 to 07-14	Microsoft discloses Storm-0558; CISA and FBI publish AA23-193A	Storm-0558	Confirmed [35][36][37]
2023-07-18 to 07-19	Estee Lauder press release and 8-K on a cybersecurity incident	Not named	Confirmed [43]
2023-07-23 and 07-28	Ivanti patches CVE-2023-35078 and CVE-2023-35081	n/a	Confirmed [45]

Date	Event	Who (as the source names them)	Grade and source
2023-07-26	SEC adopts cyber incident disclosure rules	SEC	Confirmed [46]
2023-08-01	AA23-213A with Norway's NCSC on the Ivanti exploitation	APT actors	Confirmed [45]
2023-08-02	Microsoft reports Teams social engineering against fewer than 40 organizations	Midnight Blizzard (APT29)	Confirmed [94]
2023-08-08	NIST releases the CSF 2.0 public draft with a sixth function, Govern	NIST	Confirmed [126]
2023-08-14	Clorox 8-K: IT systems taken offline, operations disrupted	Unnamed	Confirmed [47]
2023-08-25	FBI and partners take over QakBot's infrastructure. HTTP/2 Rapid Reset attacks begin at Cloudflare	QakBot operators; unnamed botnet	Confirmed [51][52][48]
2023-09-06	Microsoft publishes its key-acquisition findings for Storm-0558	Storm-0558	Confirmed [38]
2023-09-07	Citizen Lab captures BLASTPASS. Caesars determines its loyalty database was copied. Treasury and the UK sanction eleven more Trickbot members	NSO Group's Pegasus; unnamed; Trickbot	Confirmed [55][56][101]
2023-09-12	MGM Resorts announces a cybersecurity issue (8-K, 5 Oct)	Not named in the filing	Confirmed [57]
2023-09-14	Microsoft reports Peach Sandstorm password spraying from February to July	Peach Sandstorm (APT33)	Confirmed [95]
2023-09-18	Talos: earliest related Cisco IOS XE activity; MSRC publishes the SAS token post	Unnamed	Confirmed [63][58]
2023-09-20	AA23-263A on Snatch	Snatch actors	Confirmed [59]
2023-09 (late)	SVR exploitation of JetBrains TeamCity CVE-2023-42793 begins	SVR (APT29)	Confirmed [82]
2023-09-27	AA23-270A on BlackTech router firmware. Johnson Controls 8-K	BlackTech (PRC-linked); unnamed	Confirmed [60][61]
2023-09-28 to 10-17	Okta's support case system accessed through a service account; files of 134 customers viewed	Unnamed	Confirmed [65]

Date	Event	Who (as the source names them)	Grade and source
2023-10-01 to 10-10	23andMe: a threat actor posts claims; password resets required	Unnamed	Confirmed [67]
2023-10-10	NetScaler fixes CVE-2023-4966 (Citrix Bleed); KEV lists Rapid Reset CVE-2023-44487; Cloudflare and Google publish	n/a	Confirmed [69][89][48][49]
2023-10-11	AA23-284A on AvosLocker	AvosLocker affiliates	Confirmed [71]
2023-10-16	Cisco publishes the IOS XE advisory. AA23-289A on Confluence CVE-2023-22515. Ragnar Locker's key target arrested in Paris	Unnamed; unnamed; Ragnar Locker	Confirmed [62][68][100]
2023-10-20	Okta discloses the support system access	Unnamed	Confirmed [64]
2023-10-22 to 10-23	Cisco fixes roll out; NetScaler has reports of session hijacking	n/a	Confirmed [63][69]
2023-10-28	British Library identifies a ransomware attack later claimed by Rhysida	Rhysida (claimed)	Confirmed [73]
2023-10-30	SEC charges SolarWinds and its CISO. Executive Order 14110 on AI	SEC; The White House	Confirmed [74][127]
2023-11-01	Counter Ransomware Initiative's first joint policy statement	50 members	Confirmed [128]
2023-11-06	23andMe requires two-step verification	n/a	Confirmed [67]
2023-11-09	Mandiant publishes the Sandworm OT report	Sandworm	Confirmed [75]
2023-11-15 to 11-21	AA23-319A on Rhysida, AA23-320A on Scattered Spider, AA23-325A on LockBit and Citrix Bleed	Rhysida; Scattered Spider; LockBit 3.0 affiliates	Confirmed [76][77][70]
2023-11 (late)	Midnight Blizzard password-sprays a legacy Microsoft test tenant account (detected 12 Jan 2024)	Midnight Blizzard (APT29)	Confirmed [86][87]
2023-11-22 to 2024-01	CyberAv3ngers access Unitronics PLCs at US water facilities; CISA alert 28 Nov; AA23-335A 1 Dec	IRGC-affiliated CyberAv3ngers	Confirmed [78][79]
2023-11-30	OFAC designates Kimsuky	Kimsuky	Confirmed [93]
2023-12-07	AA23-341A on Star Blizzard	Star Blizzard (FSB Centre 18)	Confirmed [81]

Date	Event	Who (as the source names them)	Grade and source
2023-12 (early)	Operational action against ALPHV Blackcat	ALPHV	Confirmed [85]
2023-12-13	AA23-347A on SVR TeamCity exploitation	SVR (APT29)	Confirmed [82]
2023-12-14	Ledger Connect Kit exploited for less than two hours	Unnamed	Confirmed [83]
2023-12-18 to 12-19	AA23-352A on Play; AA23-353A on ALPHV	Play; ALPHV	Confirmed [84][85]
After the year	Microsoft 8-K on Midnight Blizzard (19 Jan 2024); Chainalysis (7 Feb 2024); CSRB review (20 Mar 2024); British Library review (8 Mar 2024); Google zero-day review (27 Mar 2024); M-Trends (23 Apr 2024); DBIR (1 May 2024); AA24-317A (12 Nov 2024)	Various	Confirmed or Reported as marked in the Parts [87][88][39][73][116][118][119][115]

Part 2: the edge-device and file-transfer year

MOVEit, in one paragraph. The home for this campaign is the Cl0p file-transfer study. Mandiant saw MOVEit Transfer exploited from 27 May 2023, with web shells and data theft, before Progress announced CVE-2023-34362 on 31 May, and on 6 June merged the cluster it had tracked as UNC4857 into FIN11 (Confirmed [30]). AA23-158A of 7 June says the CL0P Ransomware Gang, also known as TA505, began exploiting the SQL injection flaw on 27 May and used the LEMURLOOT web shell to steal data, after earlier zero-day campaigns against Accellion FTA in 2020 and 2021 and GoAnywhere MFT in early 2023 (Confirmed [31]). NVD lists CWE-89, CVSS 9.8, and KEV added it on 2 June with known ransomware use (Confirmed [104]). Chainalysis estimates the campaign took more than US$100 million (Reported [88]), and the Verizon DBIR ties much of a 180% rise in exploitation as the initial entry to MOVEit (Reported [119]).

GoAnywhere. Fortra learned on 30 January of suspicious activity in its GoAnywhere MFTaaS; an unauthorized party used the zero-day RCE CVE-2023-0669 between 28 and 30 January, and customer reports pushed on-premises activity back to 18 January (Confirmed [4]). NVD describes it as pre-authentication command injection through deserialization (CWE-502), published 6 February; KEV listed it on 10 February with known ransomware use (Confirmed [103][89]).

Barracuda ESG. Barracuda saw anomalous traffic on 18 May, identified CVE-2023-2868 on 19 May, patched all ESG appliances on 20 May and pushed a containment script on 21 May; its earliest evidence of exploitation is October 2022, and backdoors and exfiltration were found on a subset of appliances; Barracuda names the malware SALTWATER, SEASPY, SEASIDE, SKIPJACK, SEASPRAY, SANDBAR, WHIRLPOOL and SUBMARINE (Confirmed [25][26]). On 31 May and again on 6 June it said compromised appliances "must be immediately replaced regardless of patch version level", at no cost (Confirmed [26][25]). Mandiant reports that UNC4841 sent exploit emails from 10 October 2022, reached victims in at least 16 countries of which almost a third were government agencies, and assesses "with high confidence" that UNC4841 is an espionage actor in support of the PRC (Confirmed [27]). UNC4841 has no ATT&CK object in the library (Demonstrated [137]).

NVD lists CWE-77 and the CNA CWE-20; KEV listed it on 26 May (Confirmed [108]).

NetScaler, twice. In June, actors exploited CVE-2023-3519 as a zero-day to drop a web shell on a critical infrastructure organization's non-production NetScaler ADC and ran Active Directory discovery; segmentation blocked their move to a domain controller (Confirmed [44]). Citrix patched on 18 July and KEV listed it the next day; NVD lists CWE-94 (Confirmed [44][109]). NetScaler then released builds fixing CVE-2023-4966 on 10 October with no known exploitation at disclosure, and by 23 October had reports of incidents consistent with session hijacking; it told customers to kill all active and persistent sessions after upgrading (Confirmed [69]). NVD lists the CNA's CWE-119 and NVD-CWE-noinfo, CVSS 9.4; KEV added it on 18 October with known ransomware use (Confirmed [105]). AA23-325A of 21 November says LockBit 3.0 affiliates used Citrix Bleed for initial access to Boeing Distribution Inc., and asks defenders to isolate the appliances, patch, assume full admin access if compromised, reimage and issue new credentials (Confirmed [70]).

Ivanti EPMM. AA23-213A, published with Norway's NCSC on 1 August, says APT actors exploited CVE-2023-35078 as a zero-day from at least April to July 2023 against several Norwegian organizations and compromised a Norwegian government agency, chaining it with CVE-2023-35081; Ivanti patched on 23 and 28 July (Confirmed [45]). NVD lists CWE-287 and KEV added it on 25 July; KEV now flags it for known ransomware use (Confirmed [110][89]).

Cisco IOS XE. Cisco's advisory, first published 16 October, covers two web UI flaws: CVE-2023-20198 (CVSS 10.0), used for initial access and to create a privileged local account, and CVE-2023-20273 (CVSS 7.2), used to elevate to root and write an implant; Cisco strongly recommends disabling the HTTP Server feature on internet-facing systems (Confirmed [62]). Talos says a TAC case on 28 September showed suspicious activity, related activity went back to 18 September, a second cluster appeared on 12 October, fixes rolled out from 22 October, and the implant was later named BadCandy (Confirmed [63]). KEV listed the two CVEs on 16 and 23 October; NVD shows the CNA's CWE-420 and NVD-CWE-Other for CVE-2023-20198 (Confirmed [89][107]).

Atlassian, JetBrains and the rest. AA23-289A says actors exploited Confluence CVE-2023-22515 as a zero-day to create unauthorized administrator accounts and kept going after the patch; KEV listed it on 5 October (Confirmed [68][89]). Confluence CVE-2023-22518 (CWE-863) followed, published 31 October and listed on 7 November with known ransomware use (Confirmed [113]). Apache ActiveMQ CVE-2023-46604, an OpenWire deserialization RCE (CWE-502), was published on 27 October and listed on 2 November with known ransomware use (Confirmed [114]). AA23-347A says the SVR exploited TeamCity CVE-2023-42793 at large scale from late September (Part 4); NVD shows the CNA's CWE-288 and NVD's CWE-306, and KEV listed it on 4 October (Confirmed [82][106]). PaperCut CVE-2023-27350 (CNA CWE-284) was exploited from mid-April and listed on 21 April (Confirmed [21][111]). The Danish energy attacks used Zyxel CVE-2023-28771, disclosed on 25 April and listed on 31 May (Confirmed [23][89]). ColdFusion CVE-2023-26360 gave actors a foothold on two federal agency systems in June (Confirmed [80]).

Older flaws, still working. AA23-074A says multiple actors, including an APT actor, exploited Telerik UI CVE-2019-18935 on a federal civilian agency's IIS server from November 2022 through early January 2023 (Confirmed [3]). AA23-250A says nation-state APT actors were inside an aeronautical organization as early as January 2023 through ManageEngine CVE-2022-47966 and FortiOS CVE-2022-42475 (Confirmed [54]). AA23-187A says newer Truebot variants used Netwrix Auditor CVE-2022-31199 (Confirmed [40]). ESXiArgs actors likely exploited known flaws in unpatched or out-of-service ESXi servers (Confirmed [6]).

KEV in numbers. Counted from the KEV feed (catalog version 2026.11.10), 187 entries were added in calendar 2023, 121 of them CVE-2023 ids; the vendors with the most additions were Microsoft (27), Apple (21), Samsung (8), Google (7) and Cisco (7); 43 of the 187 are now flagged for known ransomware use (Demonstrated [89]). Rows flagged Known beyond those above include WS_FTP CVE-2023-40044 (5 Oct), Windows CLFS CVE-2023-28252 (11 Apr), Windows SmartScreen CVE-2023-24880 (14 Mar), SysAid CVE-2023-47246 (13 Nov) and WinRAR CVE-2023-38831 (24 Aug) (Confirmed [89]). The year's headline additions, in date order:

CVE	Product	What the record says	KEV added	Source
CVE-2023-0669	Fortra GoAnywhere MFT	Pre-auth command injection through deserialization (CWE-502); zero-day from 18 Jan; known ransomware use	2023-02-10	Confirmed [4][103][89]
CVE-2023-23397	Microsoft Outlook	Elevation of privilege used against European targets by a Russia-based actor	2023-03-14	Confirmed [12][89]
CVE-2023-26360	Adobe ColdFusion	Foothold on two federal agency systems in June	2023-03-15	Confirmed [80][89]
CVE-2023-27350	PaperCut MF/NG	Exploited from mid-April; CNA CWE-284	2023-04-21	Confirmed [21][111]
CVE-2023-2868	Barracuda ESG	Exploited from October 2022; NVD CWE-77, CNA CWE-20	2023-05-26	Confirmed [25][108]
CVE-2023-28771	Zyxel firewalls	Used against Danish energy companies from 11 May	2023-05-31	Confirmed [23][89]
CVE-2023-34362	MOVEit Transfer	SQL injection (CWE-89), CVSS 9.8; known ransomware use	2023-06-02	Confirmed [104][31]
CVE-2023-27997	FortiOS and FortiProxy SSL-VPN	Heap overflow (CWE-122); known ransomware use	2023-06-13	Confirmed [89]
CVE-2023-3519	NetScaler ADC and Gateway	Unauthenticated RCE (CWE-94), zero-day in June	2023-07-19	Confirmed [44][109]
CVE-2023-35078	Ivanti EPMM	Improper authentication (CWE-287), zero-day from April	2023-07-25	Confirmed [45][110]
CVE-2023-41064, CVE-2023-41061	Apple (BLASTPASS chain)	Zero-click iMessage chain delivering Pegasus	2023-09-11	Confirmed [55][89]
CVE-2023-42793	JetBrains TeamCity	CNA CWE-288, NVD CWE-306; SVR exploitation from late September	2023-10-04	Confirmed [106][82]
CVE-2023-22515	Confluence Data Center and Server	Zero-day used to create admin accounts	2023-10-05	Confirmed [68][89]
CVE-2023-44487	HTTP/2 (vendor IETF)	Rapid Reset DDoS (CWE-400), CVSS 7.5	2023-10-10	Confirmed [112][89]
CVE-2023-20198, CVE-2023-20273	Cisco IOS XE web UI	Account creation (CVSS 10.0), then root and implant (CVSS 7.2)	2023-10-16, 2023-10-23	Confirmed [62][107][89]
CVE-2023-4966	NetScaler ADC and Gateway (Citrix Bleed)	Information disclosure used for session hijacking; CNA CWE-119; known ransomware use	2023-10-18	Confirmed [69][105]

CVE	Product	What the record says	KEV added	Source
CVE-2023-46604	Apache ActiveMQ	OpenWire deserialization RCE (CWE-502); known ransomware use	2023-11-02	Confirmed [114]
CVE-2023-22518	Confluence Data Center and Server	Improper authorization (CWE-863); known ransomware use	2023-11-07	Confirmed [113]

KEV also listed CVE-2023-32434 and CVE-2023-32435 on 23 June and CVE-2023-6448 on 11 December (Confirmed [89]). The 3CX flaw, CVE-2023-29059, was exploited in the wild in March but is not in KEV, and NVD gives it NVD-CWE-noinfo (Confirmed [19]).

What was exploited most. AA24-317A, published on 12 November 2024, lists the top routinely exploited vulnerabilities of 2023, led by CVE-2023-3519, CVE-2023-4966, CVE-2023-20198, CVE-2023-20273, CVE-2023-27997 and CVE-2023-34362, and still including Log4Shell CVE-2021-44228 and Netlogon CVE-2020-1472 (Confirmed [115]). More zero-days were used against enterprise networks in 2023 than in 2022, and most of the top 2023 CVEs were first exploited as zero-days; even so, actors had the most success within two years of disclosure (Confirmed [115]). The Log4Shell record behind its place on that list is in the Log4Shell study. AA24-317A's CWE listings include CWE-78 for CVE-2023-20273, CWE-787 and CWE-122 for CVE-2023-27997, CWE-20 for CVE-2023-22515, CWE-294 and CWE-20 for CVE-2023-23397, CWE-200 for CVE-2023-49103 and CWE-917, 502, 20 and 400 for Log4Shell, and it asks vendors to build secure by design, remove default passwords, fill CWE fields accurately and move to memory-safe languages (Confirmed [115]).

Zero-days in numbers. Google TAG and Mandiant counted 97 zero-days exploited in the wild in 2023, up from 62 in 2022 and below 106 in 2021, with enterprise targeting rising and more focus on security software and appliances; their examples are Barracuda ESG, VMware ESXi CVE-2023-20867 used by UNC3886 (G1048) and MOVEit (Confirmed [116]). Google's companion review says enterprise-specific zero-days rose 64% and that commercial surveillance vendors were behind 75% of known zero-days against Google products and Android (Reported [117]).

Part 3: China

The wider record is in the China-attributed actors study. This Part gives the 2023 sequence.

Volt Typhoon. AA23-144A of 24 May, from the NSA, CISA, FBI and the Australian, Canadian, New Zealand and UK agencies, describes "a People's Republic of China (PRC) state-sponsored cyber actor" known as Volt Typhoon that lives off the land with built-in administration tools (WMI, ntdsutil, netsh, PowerShell) to blend in with normal activity and avoid EDR, against US critical infrastructure networks, routing traffic through compromised small office and home office devices (Confirmed [28]). Microsoft published the same day: Volt Typhoon, "a state-sponsored actor based in China", active since mid-2021, targeted critical infrastructure in Guam and elsewhere in the US, gained initial access through internet-facing Fortinet FortiGuard devices, and, Microsoft assesses with moderate confidence, is developing capabilities that could disrupt critical communications between the US and Asia in future crises (Confirmed [29]). ATT&CK created the group as G1017 on 27 July 2023; its live page lists campaigns C0035 KV Botnet Activity and C0039 Versa Director Zero Day Exploitation, a 2024 campaign outside this year (Confirmed [130]). The advisory's guidance is to harden domain controllers, watch for ntdsutil process creation, limit port proxying, review perimeter firewall changes and forward logs to a hardened central server, and it warns that these indicators overlap legitimate

administration (Confirmed [28]).

Storm-0558. Microsoft disclosed on 11 July that from 15 May a China-based actor it tracks as Storm-0558 accessed email at about 25 organizations, including government agencies, using forged authentication tokens made with an acquired MSA consumer signing key; it began investigating after a customer report on 16 June (Confirmed [35]). Its 14 July analysis adds that a token validation issue let the consumer key sign tokens accepted for enterprise (Azure AD) mail, that the actor used Outlook Web Access and an API design flaw to reach mail over Tor or SOCKS5 proxies, and that Microsoft revoked all MSA signing keys on 29 June; Microsoft now tracks the actor as Antique Typhoon (Confirmed [36]). AA23-193A, from CISA and the FBI on 12 July, says a federal civilian agency found the activity in mid-June through MailItemsAccessed events with an unexpected application id in its M365 audit logs, calls the actors "APT actors" without naming a country, and lists no ATT&CK ids (Confirmed [37]). On 6 September Microsoft called an April 2021 crash dump that carried the key into a debugging environment, plus a compromised engineer account, the "most probable mechanism"; its 12 March 2024 addendum says it has not found a crash dump containing the key (Confirmed [38]). The Cyber Safety Review Board's review, dated 20 March 2024, counts 22 organizations and over 500 individuals compromised with tokens signed by a key from 2016, says the State Department reached Microsoft on 16 June after a custom alert on the MailItemsAccessed log, found "a cascade of security failures" at Microsoft and an inadequate security culture, and says Microsoft does not know how or when the key was obtained (Confirmed [39]). Storm-0558 has no ATT&CK group object in the library (Demonstrated [137]).

UNC4841 and Barracuda. See Part 2: Mandiant's high-confidence assessment ties the ESG campaign to an espionage actor in support of the PRC (Confirmed [27]).

BlackTech. AA23-270A of 27 September, from the NSA, FBI, CISA and Japan's NPA and NISC, says "PRC-linked cyber actors known as BlackTech" (G0098) modify router firmware and exploit domain trust between routers to pivot from international subsidiaries to headquarters in Japan and the US (Confirmed [60]). The advisory's ATT&CK table covers code signing certificates, ROMMONkit, network device authentication, patched and downgraded system images, and proxying, and is bound in Part 13 (Confirmed [60]).

UNC3886. Mandiant reported on 13 June that UNC3886 (G1048), "a highly adept Chinese cyber espionage group", used VMware Tools zero-day CVE-2023-20867 to perform guest operations from compromised ESXi hosts without guest credentials (Confirmed [91]).

Part 4: Russia

The wider record is in the Russia-attributed actors study, and Sandworm's in the Sandworm study.

Snake. AA23-129A of 9 May, from US, UK, Canadian, Australian and New Zealand agencies, says Snake is the most sophisticated espionage tool of FSB Center 16, with infrastructure in over 50 countries, and states: "We attribute Snake operations to a known unit within Center 16 of the FSB" (Confirmed [22]). It has been in development since late 2003 as Uroburos (Confirmed [22]). In ATT&CK the group is G0010 Turla and the malware S0022 Uroburos, with Snake as an alias of both (Demonstrated [137]). The DOJ release on the disruption could not be opened, so its operation name is not given here.

APT28 and the routers. A joint advisory of 18 April from the NCSC, NSA, CISA and FBI says APT28 (G0007) exploited Cisco SNMP CVE-2017-6742 on routers in 2021 and deployed Jaguar Tooth malware; the CISA page names the actor only as APT28, without a GRU unit (Confirmed [90]).

Outlook. On 14 March Microsoft patched Outlook CVE-2023-23397, which a Russia-based threat actor had used in targeted attacks on a limited number of government, transportation, energy and military organizations in Europe, after a report from CERT-UA (Confirmed [12]). Microsoft's post names no ATT&CK group, so this study binds none.

APT29 and the SVR. Microsoft reported on 2 August that Midnight Blizzard, which the US and UK governments attribute to the SVR, used Microsoft Teams chats from compromised small-business tenants to trick targets into approving authenticator prompts, affecting fewer than 40 organizations (Confirmed [94]). AA23-347A of 13 December, from the FBI, CISA, NSA, Poland's SKW and CERT Polska, and the UK NCSC, says the SVR (G0016 APT29) has exploited JetBrains TeamCity CVE-2023-42793 at large scale since late September, so far without SolarWinds-style supply chain use (Confirmed [82]). Its guidance: patch, assume compromise if the server was unpatched, alert when EDR is disabled or loses contact, audit access to privileged certificates and the creation of fake identity providers, and require confirmation of sensitive actions such as registering a new device (Confirmed [82]). Then, beginning in late November, Midnight Blizzard password-sprayed a legacy non-production test tenant account at Microsoft and reached a very small percentage of corporate mailboxes, including senior leadership; Microsoft detected it on 12 January 2024 and removed access on or about 13 January, and filed an 8-K under Item 1.05 on 19 January (Confirmed [86][87]). The SolarWinds campaign that made the SVR's supply chain reputation is told in the SolarWinds study.

Star Blizzard. AA23-341A of 7 December, led by the UK NCSC with seven partners, says Star Blizzard (G1033; SEABORGIUM, Callisto, COLDRIVER) is "almost certainly subordinate to" the FSB's Centre 18, and has spearphished academia, defense, government, NGOs, think tanks and politicians since 2019, harvesting credentials and session cookies with EvilGinx (Confirmed [81]).

Sandworm, disclosed. Mandiant published on 9 November 2023 that Sandworm (G0034), which it assesses is linked to the GRU, caused a power outage at a Ukrainian substation on 10 October 2022 with an OT-level living-off-the-land action through a native MicroSCADA utility, likely tripping breakers and causing an unplanned outage that coincided with missile strikes, then deployed a new CaddyWiper (S0693) variant on 12 October (Confirmed [75]). ATT&CK records it as C0034, the 2022 Ukraine Electric Power Attack (Demonstrated [137]). The home for this event is the Sandworm study.

Denmark. SektorCERT reports that a coordinated attack targeted 16 Danish energy companies on 11 May through Zyxel CVE-2023-28771, with a second wave from 22 May; 22 energy companies were compromised in May and several had to go into island mode (Confirmed [23]). SektorCERT recorded an alarm on traffic to infrastructure associated with Sandworm but did not conclude whether the attacking groups were linked (Reported [23]); this study does not bind the attacks to Sandworm.

Part 5: North Korea and Iran

The wider records are in the North Korea-attributed actors study and the Iran-attributed actors study.

The Horizon bridge. On 23 January the FBI confirmed that Lazarus Group (G0032), which it also calls APT38 (G0082), stole US$100 million in virtual currency from Harmony's Horizon bridge, a theft reported on 24 June 2022; it updated the statement on 6 February (Confirmed [5]).

Ransomware for the state. AA23-040A of 9 February says DPRK state-sponsored actors use ransomware, including Maui and H0lyGh0st, against US and South Korean healthcare and other critical infrastructure to fund DPRK activities (Confirmed [8]). Neither has an ATT&CK object in the library (Demonstrated [137]).

3CX. On 30 March 3CX warned that its Electron Windows app shipped in Update 7, versions 18.12.407 and 18.12.416, included a security issue, and CISA issued an alert the same day calling it a supply chain attack against 3CX and its customers (Confirmed [15][18]). 3CX then relayed Mandiant's interim results: the cluster UNC4736, assessed with high confidence to have a North Korean nexus, Windows malware TAXHAUL, and DLL side-loading for persistence (Reported [16]). Mandiant's report of 20 April traces the intrusion to a tampered X_TRADER installer from Trading Technologies that deployed VEILEDSIGNAL, calls it the first software supply chain attack it had seen lead to another, and links UNC4736 with moderate confidence to AppleJeus activity (Confirmed [17]). ATT&CK records the campaign as C0057 3CX Supply Chain Attack, from November 2022 to March 2023, associated with G1049 AppleJeus, whose aliases in the library include UNC4736 (Confirmed [132]; Demonstrated [137]). NVD records CVE-2023-29059 for the embedded malicious code in 3CX DesktopApp through 18.12.416 (Confirmed [19]).

JumpCloud. JumpCloud says a nation-state actor spear-phished into its infrastructure on 22 June, the anomaly was found on 27 June, the first customer impact came on 5 July through data injection into its commands framework, it force-rotated all admin API keys on 5 July, and fewer than five customers and fewer than ten devices were affected (Confirmed [42]). Mandiant attributes the campaign to the DPRK-nexus UNC4899 and says it led to a supply chain compromise of a US software company (Confirmed [41]). UNC4899 has no ATT&CK object in the library (Demonstrated [137]).

Kimsuky. Joint advisory CSA-20230601-1, from the FBI, the State Department, the NSA and South Korea's NIS, NPA and MOFA, says DPRK actors tracked as Kimsuky (G0094; Thallium, APT43, Velvet Chollima, Black Banshee) spearphish while posing as journalists and academics, and that Kimsuky is administratively subordinate to an element within the RGB (Confirmed [92]). On 30 November OFAC designated Kimsuky under E.O. 13687 as an agency, instrumentality or controlled entity of the Government of North Korea (Confirmed [93]).

Peach Sandstorm. Microsoft reported on 14 September that Peach Sandstorm, an "Iranian nation-state group" that overlaps APT33 (G0064, whose library aliases include Peach Sandstorm), password-sprayed thousands of organizations from February to July, focusing on satellite, defense and pharmaceutical targets (Confirmed [95][137]).

CyberAv3ngers. CISA warned on 28 November that a Unitronics Vision PLC and HMI at a US water facility had been compromised, likely through weak passwords and internet exposure; the authority switched to manual operation and there was no known risk to drinking water (Confirmed [78]). AA23-335A of 1 December says IRGC-affiliated actors using the persona CyberAv3ngers compromised Israeli-made Unitronics PLCs and HMIs from 22 November, with victims in several US states and abroad; its December 2024 revision counts at least 75 devices, 34 of them in water, from November 2023 to January 2024 (Confirmed [79]). Part 9 has the industrial view.

Part 6: identity, sessions and the help desk

Okta. Okta disclosed on 20 October that a stolen credential gave access to its support case management system, letting the actor view files uploaded by certain customers (Confirmed [64]). Its root cause analysis says the access ran from 28 September to 17 October through a service account whose credential had been saved to an employee's personal Google profile, files of 134 customers (under 1%) were accessed, some were HAR files containing session tokens, and those tokens were used to hijack sessions of five customers; customers were advised on 19 October (Confirmed [65]).

23andMe. 23andMe says credential stuffing reached about 14,000 accounts, under 0.1% of its 14 million customers, and through them about 5.5 million DNA Relatives profiles and 1.4 million Family Tree profiles (Confirmed [66]). Its 8-K/A says a threat actor posted claims on 1 October, password resets were required on 10 October, two-step verification became mandatory on 6 November, and it expected one-time costs of US$1 to 2 million (Confirmed [67]).

CircleCI. Malware on an engineer's laptop stole a 2FA-backed SSO session cookie on 16 December 2022; customer secrets were exfiltrated on 22 December, and on 4 January 2023 customers were told to rotate all secrets (Confirmed [102]).

LastPass. LastPass's 1 March update says a first incident on a developer laptop yielded source code and secrets used to plan a second, in which a senior DevOps engineer was targeted through vulnerable third-party software and cloud backups including encrypted customer vault data were taken; it saw no threat actor activity after 26 October 2022 (Confirmed [10]).

The casinos. Caesars' 8-K of 14 September describes a social engineering attack on an outsourced IT support vendor and says that on 7 September it determined the actor had copied the loyalty program database, including driver's licence and/or Social Security numbers for a significant number of members (Confirmed [56]). MGM Resorts' 8-K of 5 October says it announced a cybersecurity issue on 12 September and shut down systems, expected about a US$100 million negative impact on Adjusted Property EBITDAR, and saw September Las Vegas occupancy of 88% against 93% a year earlier (Confirmed [57]). Neither filing names an actor; Chainalysis reports that ALPHV-BlackCat and Scattered Spider targeted MGM and that MGM did not pay (Reported [88]).

Scattered Spider. AA23-320A, first published on 16 November 2023, describes Scattered Spider (G1015) targeting large companies and their IT help desks with layered social engineering, SIM swaps and MFA fatigue (Confirmed [77]). The live page carries a 29 July 2025 update that also describes the actor registering its own MFA devices and adding a federated identity provider to SSO, along with later behavior such as DragonForce; because the 2023 original was not opened separately, this study does not date that material to 2023 (Confirmed [77]; Inferred for the decision). AA23-320A does not name MGM or Caesars, so this study does not make that link on CISA's authority (Confirmed [77]). Its mitigations ask for phishing-resistant MFA (FIDO/WebAuthn or PKI), allowlisting of remote access software, NIST-aligned password policy and offline immutable backups, and none is written specifically for the help desk (Confirmed [77]).

ALPHV affiliates. AA23-353A says ALPHV Blackcat (S1068) affiliates impersonate IT or help-desk staff by phone or SMS to get credentials, use compromised accounts and adversary-in-the-middle phishing (Confirmed [85]). The figures on victims and healthcare come from the February 2024 revision (Part 7).

Tokens and sessions. Storm-0558's forged tokens (Part 3), Citrix Bleed's hijacked sessions (Part 2), Okta's HAR files and CircleCI's stolen session cookie each let an actor skip a login entirely; the control that answers all four is session and token revocation with short token lifetimes (Confirmed [36][69][65][102]; Inferred for the control).

Other identity paths. T-Mobile found on 5 January that a bad actor had pulled data through a single API since about 25 November 2022, affecting about 37 million postpaid and prepaid accounts, with no payment card, SSN or password data through that API (Confirmed [2]). AA23-025A describes a campaign from October 2022 in which phishing led victims to install legitimate remote monitoring and management software, ScreenConnect and AnyDesk, which was then used in a refund scam to steal from their bank accounts

(Confirmed [1]). Microsoft's own January 2024 disclosure of Midnight Blizzard's password spray on a legacy test tenant (Part 4) closed the year (Confirmed [86]).

Part 7: ransomware, extortion and the money

The year's advisories. CISA and its partners published a ransomware advisory in most months of 2023:

Advisory	Date	Group	What it says	Source
AA23-039A	8 Feb	ESXiArgs	Over 3,800 ESXi servers compromised globally through known flaws in unpatched or out-of-service servers; CISA recovery script	Confirmed [6][7]
AA23-040A	9 Feb	Maui, H0lyGh0st (DPRK)	Healthcare and other critical infrastructure in the US and South Korea, to fund the DPRK	Confirmed [8]
AA23-061A	2 Mar	Royal	Used from about September 2022; updated 13 Nov 2023; renamed BlackSuit in the August 2024 update	Confirmed [11]
AA23-075A	16 Mar	LockBit 3.0	More modular and evasive than earlier versions	Confirmed [13]
AA23-131A	11 May	Bl00dy Ransomware Gang	PaperCut CVE-2023-27350 against the education subsector in early May	Confirmed [21]
AA23-136A	May	BianLian	US critical infrastructure since June 2022 and Australian critical infrastructure; access with valid RDP credentials; updated 20 Nov 2024	Confirmed [24]
AA23-158A	7 Jun	CL0P (TA505)	MOVEit Transfer zero-day from 27 May; LEMURLOOT web shell	Confirmed [31]
AA23-165A	14 Jun	LockBit	Most deployed variant worldwide in 2022 and prolific in 2023; about 1,700 US attacks and about US$91 million in US ransoms since 5 Jan 2020; with seven international partners	Confirmed [34]
AA23-187A	6 Jul	Truebot	Phishing and Netwrix CVE-2022-31199; used by CL0P; US and Canadian networks	Confirmed [40]
AA23-263A	20 Sep	Snatch	Evolving since mid-2021; double extortion against the defense industrial base, food and agriculture and IT	Confirmed [59]
AA23-284A	11 Oct	AvosLocker	Multiple US critical infrastructure sectors across Windows, Linux and ESXi	Confirmed [71]
AA23-319A	15 Nov	Rhysida	Since May 2023 against education, healthcare, manufacturing, IT and government; similarities with Vice Society in open-source reporting	Confirmed [76]
AA23-320A	16 Nov	Scattered Spider	Help-desk social engineering, MFA fatigue, SIM swaps (2025 revision on the live page)	Confirmed [77]
AA23-325A	21 Nov	LockBit 3.0 affiliates	Citrix Bleed for initial access to Boeing Distribution Inc.	Confirmed [70]
AA23-352A	18 Dec	Play	Since June 2022 in North America, South America and Europe; first Australian incident April 2023	Confirmed [84]
AA23-353A	19 Dec	ALPHV Blackcat	Operational action in early December; nearly 70 leaked victims since mid-December, with healthcare most victimized (February 2024 revision)	Confirmed [85]

The library has ATT&CK pages for S0611 Clop, G0092 TA505, S1073 Royal, S1202 LockBit 3.0, S1199 LockBit 2.0, S1053 AvosLocker, G1040 Play and its ransomware S1162 Playcrypt, S1068 BlackCat and G1015 Scattered Spider; ESXiArgs, Maui, H0lyGh0st, Bl00dy, BianLian, Truebot, Snatch, Rhysida and Hive have no ATT&CK object in the library (Demonstrated [137]). The healthcare view of these groups is in the healthcare threat actor watchlist, and the ransomware business across 2019 to 2026, Hive, LockBit, ALPHV, Royal and Play among it, is the subject of the ransomware ecosystem study.

Victims who filed. DISH said on its 23 February earnings call that an outage was caused by a cyber-security incident, learned on 27 February that data had been extracted, and its 8-K refers to a ransomware attack (Confirmed [9]). Clorox took IT systems offline after unauthorized activity that disrupted parts of its business (8-K, 14 August) (Confirmed [47]). Johnson Controls reported an incident that disrupted portions of its internal IT and business operations (8-K, 27 September) (Confirmed [61]). Estee Lauder issued a press release on 18 July and filed an 8-K the next day; the incident details sit in the exhibit, which was not opened (Confirmed [43]). These filings came before the 18 December compliance date for the SEC's new Item 1.05 (Part 11).

The British Library. The Library says it suffered a significant cyber-attack in October that disrupted many services (Confirmed [72]). Its March 2024 review says the ransomware attack was identified on 28 October, was claimed by Rhysida, about 600GB of data was taken and dumped, and the first detected unauthorized access was at a Terminal Services server not covered by MFA (Confirmed [73]).

Arrests, sanctions and takedowns. On 26 January Europol supported German, Dutch and US authorities in shutting down Hive's infrastructure and giving decryption tools to victims; since June 2021 Hive had hit over 1,500 companies in over 80 countries for nearly EUR 100 million in ransom, with affiliates keeping 80 percent and developers 20 percent (Confirmed [96]). On 9 February Treasury and the UK jointly sanctioned seven members of the Russia-based Trickbot gang (S0266), the UK's first cyber sanctions of their kind, and on 7 September they designated eleven more; Treasury says the DOJ unsealed nine Trickbot and Conti indictments that day (Confirmed [97][101]). On 5 April Genesis Market, which listed identities of over 2 million people, was taken down in an action led by the FBI and the Dutch National Police, with 119 arrests, 208 property searches and 97 knock-and-talk measures (Confirmed [98]). On 16 May Treasury designated Mikhail Matveev, named him as central to the development and deployment of Hive, LockBit and Babuk (S0638), and noted indictments in New Jersey and Washington and a State Department reward of up to US$10 million (Confirmed [99]). On 25 August the FBI and international partners took over QakBot (S0650): the FBI identified more than 700,000 infected computers worldwide, over 200,000 in the US, and redirected their traffic to push an uninstaller; Europol adds nearly EUR 54 million in ransom-linked fees to the administrators from October 2021 to April 2023 and nearly EUR 8 million in cryptocurrency seized; AA23-242A warns the disruption does not remove malware already installed (Confirmed [52][53][51]). From 16 to 20 October a French-led action took down Ragnar Locker (S0481): a key target arrested in Paris on 16 October, searches in Czechia, Spain and Latvia, infrastructure seized in the Netherlands, Germany and Sweden, and the leak site taken down (Confirmed [100]). AA23-353A refers to operational action against ALPHV in early December; the DOJ release could not be opened, so its figures are not given (Confirmed [85]).

The money record. Chainalysis estimates that ransomware payments in 2023 passed US$1 billion, the highest it has observed, reversing a 2022 dip; its figures are conservative and are revised upward over time (its 2022 figure rose 24.1 percent) (Reported [88]). The FBI's IC3 2023 report counts 880,418 complaints and over US$12.5 billion in losses, business email compromise at US$2.9 billion, and 2,825 ransomware complaints with adjusted losses over US$59.6 million, 1,193 of them from critical infrastructure in 14 of 16

sectors; the top variants against critical infrastructure were LockBit, ALPHV/BlackCat, Akira (G1024; S1129 Akira), Royal and Black Basta (S1070) (Confirmed [120]). IC3 says its ransomware losses exclude lost business and remediation costs and are artificially low (Confirmed [120]). The two figures measure different things (Inferred [88][120]).

Part 8: supply chain, cloud and denial of service

Supply chain. 3CX and JumpCloud are told in Part 5 and CircleCI and LastPass in Part 6. Ledger says that on 14 December its Ledger Connect Kit, a JavaScript library that connects websites to wallets, was exploited, and that the exploit ran for less than two hours (Confirmed [83]). Package-registry attacks are told in the npm supply chain study and machine-learning supply chains in the Hugging Face study.

Cloud exposure. Microsoft said on 18 September that, after a report from Wiz on 22 June, it remediated an overly permissive SAS token shared in a public GitHub repository, revoking it on 24 June; the exposed storage held workstation backups and Teams messages of two former employees, and no customer data was exposed (Confirmed [58]). The 38 TB figure widely quoted for this exposure is not on Microsoft's page and the Wiz post was not opened.

The cloud provider as the victim. Storm-0558 (Part 3) is the year's defining cloud case: the intrusion ran through Microsoft's own signing infrastructure, and customers could see it only if they paid for the right logs (Confirmed [39]; Inferred for the framing).

Denial of service. Microsoft says that from early June layer 7 DDoS surges by Storm-1359 temporarily affected some services, with no evidence customer data was accessed (Confirmed [33]). From 25 August Cloudflare saw HTTP/2 Rapid Reset attacks peaking just above 201 million requests per second from a botnet of about 20,000 machines (Confirmed [48]); Google mitigated a peak of 398 million requests per second in a wave that began in late August (Confirmed [49]); and AWS detected the new event type from late August (Confirmed [50]). The flaw, CVE-2023-44487 (CWE-400), was listed in KEV on 10 October (Confirmed [112][89]).

Part 9: industrial and critical infrastructure

For the earlier ICS record see the Stuxnet study, and for the years that followed the ICS attacks and advisories study, 2024 to 2026.

Water. The Unitronics compromises (Part 5) likely came through poor password security and internet exposure, on devices that had a default password or none; AA23-335A asks operators to replace default passwords, take PLCs off the internet, require MFA for OT access, segment networks and keep backups of PLC logic (Confirmed [78][79]). The advisory maps Enterprise techniques only (Confirmed [79]). ATT&CK's live CyberAv3ngers page, G1027, ties ICS techniques to the 2023 Unitronics activity under campaign C0031 (November 2023); its other techniques belong to a 2026 campaign and are not dated to 2023 here (Confirmed [131]). The library has no G1027 group page, no C0031 campaign and no ICS technique pages, so these ids appear unlinked in Part 13 (Demonstrated [137]).

Energy. The Danish attacks reached 22 energy companies through their Zyxel firewalls, the first wave through CVE-2023-28771, and several went to island mode (Part 4; Confirmed [23]). Sandworm's 2022 substation outage, disclosed in November 2023, used the operator's own SCADA tooling (Part 4; Confirmed [75]).

Pre-positioning. Volt Typhoon's targeting of US critical infrastructure, and Microsoft's assessment that it was building disruptive capability, mark a shift from collection to preparation (Confirmed [28][29]; Inferred for the shift). BlackTech's pivot from subsidiary routers to headquarters shows how a trusted network path reaches a parent company (Confirmed [60]).

Healthcare as infrastructure. DPRK ransomware against healthcare, ALPHV's healthcare focus after its disruption, and Rhysida's victims in healthcare and education put patient services in the ransomware record for the year (Confirmed [8][85][76]).

Part 10: spyware and mobile zero-days

The home for the commercial exploit market is the zero-day market study.

Operation Triangulation. Kaspersky disclosed on 1 June that iOS devices were compromised through an iMessage attachment exploit that needed no user interaction (Confirmed [32]).

BLASTPASS. Citizen Lab captured on 7 September a zero-click iMessage chain that used PassKit attachments to deliver NSO Group's Pegasus to an employee of a Washington DC civil society organization; the CVEs are CVE-2023-41064 and CVE-2023-41061, listed in KEV on 11 September (Confirmed [55][89]).

Policy. On 27 March the President signed an executive order prohibiting US government operational use of commercial spyware that poses counterintelligence or security risks or has been misused for human-rights abuses (Confirmed [124]). Google reports that commercial surveillance vendors were behind 75% of the known zero-days against Google products and Android in 2023 (Reported [117]).

Part 11: the government record

Strategy. The National Cybersecurity Strategy, released on 2 March, set five pillars and rebalanced responsibility toward those best placed to reduce risk, including a shift of liability toward software makers (Confirmed [122]). CISA's Secure by Design guidance appeared in April and was updated on 25 October with 17 US and international partners (Confirmed [125]). On 13 March CISA set up its Ransomware Vulnerability Warning Pilot under CIRCIA and first notified 93 organizations running Exchange vulnerable to ProxyNotShell (Confirmed [123]).

Disclosure. The SEC adopted rules on 26 July requiring disclosure of material cybersecurity incidents on Form 8-K Item 1.05 within four business days of a materiality determination, with 8-K compliance from the later of 90 days after publication or 18 December 2023, and annual risk management disclosure for fiscal years ending on or after 15 December 2023 (Confirmed [46]). Microsoft's January 2024 filing on Midnight Blizzard was made under the new item (Confirmed [87]). On 30 October the SEC charged SolarWinds and its CISO with fraud and internal control failures over cybersecurity risks from the October 2018 IPO to the December 2020 SUNBURST disclosure; the later course of the case was not checked (Confirmed [74]). The incident itself is told in the SolarWinds study.

Frameworks and AI. NIST released the CSF 2.0 public draft on 8 August, adding a sixth function, Govern, with comments due 4 November (Confirmed [126]). Executive Order 14110 of 30 October set NIST red-team guidance, reporting for dual-use foundation models trained above 10^26 operations, DoD and DHS AI cyber-defense pilots and reporting by IaaS providers on foreign customers (Confirmed [127]).

Ransomware policy. The Counter Ransomware Initiative, with 50 members including the EU and INTERPOL, issued its first joint policy statement on 1 November: national-government institutions should not pay ransomware extortion demands, and Treasury would share illicit wallet data (Confirmed [128]). Treasury's sanctions on Trickbot members, Matveev and Kimsuky are in Parts 5 and 7 (Confirmed [97][101][99][93]).

Europe. The NIS2 Directive entered into force in January 2023, with transposition due by 17 October 2024 and NIS1 repealed on 18 October 2024 (Confirmed [121]). The Cyber Resilience Act entered into force on 10 December 2024, with reporting obligations from 11 September 2026 and main obligations from 11 December 2027; its 2023 political agreement date was not on the page opened (Confirmed [129]).

Part 12: the defender view

Patch the KEV list first, then assume the appliance is lost. The 2023 guidance moved from patch to patch-and-rebuild: Barracuda's replacement order, AA23-325A's reimage and new credentials, AA23-347A's assume compromise, and NetScaler's session kill (Confirmed [26][70][82][69]). AA23-158A adds auditing remote access tools, application allowlisting, phishing-resistant MFA, KEV-first patching, offline immutable backups and a check for leftover CL0P admin accounts on rebuilt MOVEit servers (Confirmed [31]).

Identity controls that held up. AA23-320A and AA23-353A ask for phishing-resistant MFA and allowlisting of remote access software (Confirmed [77][85]). AA23-347A asks for confirmation of sensitive actions such as registering a new device and for audits of the creation of fake identity providers (Confirmed [82]). The help desk needs its own verification procedure, which AA23-320A's mitigations do not spell out (Inferred [77]).

Logging as a control. The CSRB's Recommendation 4 asks cloud providers to stop selling security-related logging as an add-on and to adopt a minimum standard for default audit logging (Confirmed [39]). AA23-193A asks customers to enable Purview Audit (Premium) logging (Confirmed [37]). AA23-144A asks for logs forwarded to a hardened central server (Confirmed [28]).

Hunting cues from the record. At the advisory level, and without commands. Each cue is this study's reading of a behavior the sources describe (behaviors Confirmed; cues Inferred):

- Edge appliances: new local or admin accounts on network devices and collaboration servers (Cisco IOS XE, Confluence), web shells on file-transfer and ADC appliances, and firmware or image changes on routers (Confirmed [62][68][31][44][60]).
- Identity: mailbox access by unexpected application ids, sessions reused from new locations after an appliance patch, bursts of MFA prompts (AA23-320A), and new device registrations or newly created identity providers (AA23-347A) (Confirmed [37][69][77][82]).
- Living off the land: ntdsutil, WMI and netsh use on domain controllers outside change windows, and port proxy configuration on Windows hosts (Confirmed [28]).
- Remote access tools: ScreenConnect, AnyDesk and similar tools appearing on hosts that do not use them (Confirmed [1][77]).
- OT: PLCs reachable from the internet with default passwords (Confirmed [78][79]).

Exposure management. M-Trends measured a global median dwell time of 10 days in 2023, down from 16 in 2022, and noted that edge devices lacking EDR were increasingly targeted (Reported [118]). The DBIR says organizations took 55 days to remediate half of their critical vulnerabilities, against a median of 5 days to mass exploitation of KEV entries (Reported [119]). See the library's Vulnerability Prioritization Reference and Edge

Device Security Reference.

Part 13: MITRE mappings

This Part binds the verified 2023 record to MITRE ATT&CK v20.0, CWE, CAPEC and D3FEND, with every id checked against the library's data files (`data/attack/technique_profiles.jsonl`, `data/attack/ics/technique_profiles.jsonl`, `data/attack/superseded_by.jsonl`, `data/attack/technique_to_d3fend.jsonl`, `data/attack/d3fend_countermeasures.jsonl`, `data/weaknesses/cwe.jsonl`, and the group, software and campaign files) and the generated pages under `mitre/` on 11 November 2026 (Demonstrated [134][135][136][137][138][139]). Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment.

Each row carries a basis. **Source** means an opened advisory or ATT&CK page prints the ATT&CK id itself. **Behavior** means the source describes the behavior and this study assigns the id (the behavior is Confirmed; the mapping is this study's reading). **Inferred** means the id rests on this study's reading of a source that lists no ids, for an actor with no ATT&CK object (Storm-0558). The advisories' v13 and v14 ids were resolved against v20.0: T1574.002 DLL Side-Loading is revoked into T1574.001 DLL, T1070.001 into T1685.005 Clear Windows Event Logs, T1562 and T1562.001 and T1562.006 into T1685 Disable or Modify Tools, T1562.003 into T1690 Prevent Command History Logging, T1562.009 into T1688 Safe Mode Boot, and T1656 into T1684.001 Impersonation (Demonstrated [134]).

ATT&CK Enterprise techniques

Id	Name	Tactic (v20.0)	Where it appears in the 2023 record	Basis	Source
T1589	Gather Victim Identity Information	Reconnaissance	AA23-341A table (Star Blizzard, 7 Dec)	Source	[81]
T1590	Gather Victim Network Information	Reconnaissance	AA23-347A table (SVR, 13 Dec)	Source	[82]
T1590.004	Gather Victim Network Information: Network Topology	Reconnaissance	AA23-347A table	Source	[82]
T1592.002	Gather Victim Host Information: Software	Reconnaissance	AA23-347A table	Source	[82]
T1593	Search Open Websites/Domains	Reconnaissance	AA23-341A table	Source	[81]
T1598	Phishing for Information	Reconnaissance	AA23-353A table (ALPHV affiliates, 19 Dec)	Source	[85]
T1598.004	Phishing for Information: Spearphishing Voice	Reconnaissance	AA23-320A table (help-desk impersonation, 16 Nov; live page revised 2025)	Source	[77]
T1583.001	Acquire Infrastructure: Domains	Resource Development	AA23-341A table	Source	[81]
T1585.001	Establish Accounts: Social Media Accounts	Resource Development	AA23-341A table	Source	[81]
T1585.002	Establish Accounts: Email Accounts	Resource Development	AA23-341A table	Source	[81]
T1586	Compromise Accounts	Resource Development	AA23-353A table	Source	[85]
T1586.002	Compromise Accounts: Email Accounts	Resource Development	AA23-341A table	Source	[81]
T1588.003	Obtain Capabilities: Code Signing Certificates	Resource Development	AA23-270A table (BlackTech, 27 Sep)	Source	[60]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA23-341A table; BianLian's valid RDP credentials (AA23-136A) and Okta's saved service account credential (Sep to Oct) as Behavior	Source; Behavior	[81][24][65]
T1078.001	Valid Accounts: Default Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	AA23-335A table (CyberAv3ngers, 1 Dec)	Source	[79]

Id	Name	Tactic (v20.0)	Where it appears in the 2023 record	Basis	Source
T1133	External Remote Services	Persistence, Initial Access	British Library Terminal Services server without MFA (Oct)	Behavior	[73]
T1189	Drive-by Compromise	Initial Access	ATT&CK campaign C0057 (3CX)	Source	[132]
T1190	Exploit Public-Facing Application	Initial Access	AA23-144A, AA23-158A, AA23-213A and AA23-347A tables; behavior in Telerik (AA23-074A), GoAnywhere (Jan), ESXiArgs (Feb), PaperCut (Apr), Zyxel in Denmark (May), Barracuda ESG, Fortinet for Volt Typhoon, NetScaler (Jun, Oct), ColdFusion (Jun), ManageEngine and FortiOS (AA23-250A), Confluence and Cisco IOS XE (Oct)	Source; Behavior	[28][31][45][82][3][4][6][21][23][25][29][44][80][54][68][62][70]
T1195.002	Supply Chain Compromise: Compromise Software Supply Chain	Initial Access	ATT&CK campaign C0057 (3CX, Mar); JumpCloud's downstream compromise of a US software company (Jul) as Behavior	Source; Behavior	[132][41]
T1199	Trusted Relationship	Initial Access	AA23-270A table (subsidiary routers to headquarters)	Source	[60]
T1566	Phishing	Initial Access	AA23-158A table; phishing to RMM installs (AA23-025A), Truebot (AA23-187A), the JumpCloud spear-phish (22 Jun) and Kimsuky's journalist personas (1 Jun) as Behavior	Source; Behavior	[31][1][40][42][92]
T1566.001	Phishing: Spearphishing Attachment	Initial Access	AA23-341A table	Source	[81]
T1566.002	Phishing: Spearphishing Link	Initial Access	AA23-341A table	Source	[81]
T1566.003	Phishing: Spearphishing via Service	Initial Access	Midnight Blizzard's Teams chats from compromised tenants (2 Aug)	Behavior	[94]
T1566.004	Phishing: Spearphishing Voice	Initial Access	AA23-320A table (live page revised 2025)	Source	[77]
T1047	Windows Management Instrumentation	Execution	AA23-144A and AA23-347A tables	Source	[28][82]
T1059	Command and Scripting Interpreter	Execution	AA23-213A table (Ivanti EPMM, 1 Aug)	Source	[45]

Id	Name	Tactic (v20.0)	Where it appears in the 2023 record	Basis	Source
T1059.001	Command and Scripting Interpreter: PowerShell	Execution	AA23-144A, AA23-158A and AA23-347A tables	Source	[28][31][82]
T1059.003	Command and Scripting Interpreter: Windows Command Shell	Execution	AA23-144A, AA23-158A and AA23-347A tables	Source	[28][31][82]
T1129	Shared Modules	Execution	AA23-158A table	Source	[31]
T1203	Exploitation for Client Execution	Execution	AA23-347A table	Source	[82]
T1053.005	Scheduled Task/Job: Scheduled Task	Execution, Persistence, Privilege Escalation	AA23-347A table	Source	[82]
T1098	Account Manipulation	Persistence, Privilege Escalation	AA23-347A table	Source	[82]
T1136	Create Account	Persistence	Unauthorized Confluence administrator accounts (AA23-289A, Oct)	Behavior	[68]
T1136.001	Create Account: Local Account	Persistence	Privileged local account on Cisco IOS XE (Oct)	Behavior	[62]
T1505.001	Server Software Component: SQL Stored Procedures	Persistence	AA23-347A table	Source	[82]
T1505.003	Server Software Component: Web Shell	Persistence	AA23-144A, AA23-158A and AA23-213A tables; NetScaler web shell (AA23-201A) as Behavior	Source; Behavior	[28][31][45][44]
T1542.004	Pre-OS Boot: ROMMONkit	Stealth, Persistence	AA23-270A table	Source	[60]
T1543.004	Create or Modify System Process: Launch Daemon	Persistence, Privilege Escalation	ATT&CK campaign C0057	Source	[132]
T1546.011	Event Triggered Execution: Application Shimming	Privilege Escalation, Persistence	AA23-158A table	Source	[31]
T1547	Boot or Logon Autostart Execution	Persistence, Privilege Escalation	AA23-347A table	Source	[82]
T1068	Exploitation for Privilege Escalation	Privilege Escalation	AA23-158A and AA23-347A tables; Cisco CVE-2023-20273 to root as Behavior	Source; Behavior	[31][82][62]
T1055	Process Injection	Stealth, Privilege Escalation	AA23-158A and AA23-347A tables	Source	[31][82]

Id	Name	Tactic (v20.0)	Where it appears in the 2023 record	Basis	Source
T1055.002	Process Injection: Portable Executable Injection	Stealth, Privilege Escalation	ATT&CK campaign C0057	Source	[132]
T1027.001	Obfuscated Files or Information: Binary Padding	Stealth	AA23-347A table	Source	[82]
T1036	Masquerading	Stealth	AA23-347A table	Source	[82]
T1036.005	Masquerading: Match Legitimate Resource Name or Location	Stealth	AA23-213A table	Source	[45]
T1070	Indicator Removal	Stealth	AA23-144A, AA23-158A and AA23-213A tables	Source	[28][31][45]
T1564	Hide Artifacts	Stealth	AA23-347A table	Source	[82]
T1564.001	Hide Artifacts: Hidden Files and Directories	Stealth	AA23-347A table	Source	[82]
T1574.001	Hijack Execution Flow: DLL	Stealth, Execution	AA23-158A and AA23-347A printed T1574.002, revoked into T1574.001; C0057 lists T1574.001	Source	[31][82][132][134]
T1620	Reflective Code Loading	Stealth	ATT&CK campaign C0057	Source	[132]
T1218.015	System Binary Proxy Execution: Electron Applications	Stealth	ATT&CK campaign C0057	Source	[132]
T1684.001	Social Engineering: Impersonation	Stealth	AA23-320A printed T1656, revoked into T1684.001 (live page revised 2025); ALPHV affiliates posing as IT staff (AA23-353A) and Kimsuky posing as journalists as Behavior	Source; Behavior	[77][85][92][134]
T1205	Traffic Signaling	Stealth, Persistence, Command and Control	AA23-270A table	Source	[60]
T1112	Modify Registry	Defense Impairment, Persistence	AA23-270A table	Source	[60]
T1553.002	Subvert Trust Controls: Code Signing	Defense Impairment	AA23-270A table; ATT&CK campaign C0057	Source	[60][132]
T1553.006	Subvert Trust Controls: Code Signing Policy Modification	Defense Impairment	AA23-270A table	Source	[60]

Id	Name	Tactic (v20.0)	Where it appears in the 2023 record	Basis	Source
T1556.004	Modify Authentication Process: Network Device Authentication	Defense Impairment, Persistence, Credential Access	AA23-270A table	Source	[60]
T1556.006	Modify Authentication Process: Multi-Factor Authentication	Defense Impairment, Persistence, Credential Access	AA23-325A table (Citrix Bleed, 21 Nov)	Source	[70]
T1601.001	Modify System Image: Patch System Image	Defense Impairment	AA23-270A table	Source	[60]
T1601.002	Modify System Image: Downgrade System Image	Defense Impairment	AA23-270A table	Source	[60]
T1685	Disable or Modify Tools	Defense Impairment	AA23-347A printed T1562.001; AA23-270A printed T1562, T1562.001 and T1562.006; all revoked into T1685	Source	[82][60][134]
T1685.005	Disable or Modify Tools: Clear Windows Event Logs	Defense Impairment	AA23-144A printed T1070.001, revoked into T1685.005	Source	[28][134]
T1688	Safe Mode Boot	Defense Impairment	AA23-263A printed T1562.009, revoked into T1688 (Snatch, 20 Sep)	Source	[59][134]
T1690	Prevent Command History Logging	Defense Impairment	AA23-270A printed T1562.003, revoked into T1690	Source	[60][134]
T1003	OS Credential Dumping	Credential Access	AA23-144A table	Source	[28]
T1003.001	OS Credential Dumping: LSASS Memory	Credential Access	AA23-347A table	Source	[82]
T1003.002	OS Credential Dumping: Security Account Manager	Credential Access	AA23-347A table	Source	[82]
T1003.003	OS Credential Dumping: NTDS	Credential Access	AA23-144A table	Source	[28]
T1110	Brute Force	Credential Access	AA23-144A and AA23-335A tables	Source	[28][79]
T1110.003	Brute Force: Password Spraying	Credential Access	AA23-144A table; Peach Sandstorm (Feb to Jul) and Midnight Blizzard against Microsoft (late Nov) as Behavior	Source; Behavior	[28][95][86]
T1110.004	Brute Force: Credential Stuffing	Credential Access	23andMe, about 14,000 accounts (Oct)	Behavior	[66]

Id	Name	Tactic (v20.0)	Where it appears in the 2023 record	Basis	Source
T1539	Steal Web Session Cookie	Credential Access	AA23-341A and AA23-325A tables; the CircleCI SSO session cookie (Dec 2022) as Behavior	Source; Behavior	[81][70][102]
T1555	Credentials from Password Stores	Credential Access	AA23-144A and AA23-353A tables	Source	[28][85]
T1555.003	Credentials from Password Stores: Credentials from Web Browsers	Credential Access	AA23-347A table	Source	[82]
T1557	Adversary-in-the-Middle	Credential Access, Collection	AA23-353A table	Source	[85]
T1558	Steal or Forge Kerberos Tickets	Credential Access	AA23-353A table	Source	[85]
T1558.001	Steal or Forge Kerberos Tickets: Golden Ticket	Credential Access	AA23-347A table	Source	[82]
T1606	Forge Web Credentials	Credential Access	Storm-0558 forged tokens with an acquired MSA signing key (from 15 May)	Inferred	[36][39]
T1621	Multi-Factor Authentication Request Generation	Credential Access	AA23-320A table (MFA fatigue in the 2023 original); Midnight Blizzard's authenticator prompts over Teams (2 Aug) as Behavior	Source; Behavior	[77][94]
T1016	System Network Configuration Discovery	Discovery	AA23-144A table	Source	[28]
T1018	Remote System Discovery	Discovery	AA23-158A and AA23-213A tables	Source	[31][45]
T1033	System Owner/User Discovery	Discovery	AA23-144A and AA23-347A tables	Source	[28][82]
T1046	Network Service Discovery	Discovery	AA23-347A table	Source	[82]
T1057	Process Discovery	Discovery	AA23-347A table	Source	[82]
T1069.001	Permission Groups Discovery: Local Groups	Discovery	AA23-144A table	Source	[28]
T1069.002	Permission Groups Discovery: Domain Groups	Discovery	AA23-144A table	Source	[28]
T1082	System Information Discovery	Discovery	AA23-144A and AA23-325A tables	Source	[28][70]

Id	Name	Tactic (v20.0)	Where it appears in the 2023 record	Basis	Source
T1087.002	Account Discovery: Domain Account	Discovery	AA23-213A table	Source	[45]
T1021.001	Remote Services: Remote Desktop Protocol	Lateral Movement	AA23-270A table	Source	[60]
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral Movement	AA23-158A table	Source	[31]
T1021.004	Remote Services: SSH	Lateral Movement	AA23-270A table	Source	[60]
T1210	Exploitation of Remote Services	Lateral Movement	AA23-347A table	Source	[82]
T1550.001	Use Alternate Authentication Material: Application Access Token	Lateral Movement	Storm-0558's forged tokens replayed against mail	Inferred	[36]
T1550.004	Use Alternate Authentication Material: Web Session Cookie	Lateral Movement	AA23-341A table; HAR session tokens used to hijack five Okta customers' sessions as Behavior	Source; Behavior	[81][65]
T1563	Remote Service Session Hijacking	Lateral Movement	AA23-325A table	Source	[70]
T1563.002	Remote Service Session Hijacking: RDP Hijacking	Lateral Movement	AA23-158A table	Source	[31]
T1005	Data from Local System	Collection	AA23-213A table	Source	[45]
T1113	Screen Capture	Collection	AA23-158A table	Source	[31]
T1114.002	Email Collection: Remote Email Collection	Collection	AA23-341A table; Storm-0558's mail access as Inferred	Source; Inferred	[81][36]
T1114.003	Email Collection: Email Forwarding Rule	Collection	AA23-341A table	Source	[81]
T1530	Data from Cloud Storage	Collection	LastPass cloud backups taken (2022, disclosed 1 Mar)	Behavior	[10]
T1071	Application Layer Protocol	Command and Control	AA23-158A table	Source	[31]
T1071.002	Application Layer Protocol: File Transfer Protocols	Command and Control	AA23-270A table	Source	[60]
T1090	Proxy	Command and Control	AA23-144A, AA23-213A and AA23-270A tables; Storm-0558's Tor and SOCKS5 proxies as Inferred	Source; Inferred	[28][45][60][36]

Id	Name	Tactic (v20.0)	Where it appears in the 2023 record	Basis	Source
T1090.001	Proxy: Internal Proxy	Command and Control	AA23-213A table	Source	[45]
T1090.002	Proxy: External Proxy	Command and Control	AA23-144A and AA23-270A tables; Volt Typhoon's SOHO devices (Microsoft) as Behavior	Source; Behavior	[28][60][29]
T1102.001	Web Service: Dead Drop Resolver	Command and Control	ATT&CK campaign C0057	Source	[132]
T1105	Ingress Tool Transfer	Command and Control	AA23-158A table	Source	[31]
T1219	Remote Access Tools	Command and Control	AA23-320A table (live page revised 2025); ScreenConnect and AnyDesk in the refund scam (AA23-025A) as Behavior	Source; Behavior	[77][1]
T1568	Dynamic Resolution	Command and Control	AA23-347A table	Source	[82]
T1572	Protocol Tunneling	Command and Control	AA23-213A and AA23-347A tables	Source	[45][82]
T1020	Automated Exfiltration	Exfiltration	AA23-347A table	Source	[82]
T1041	Exfiltration Over C2 Channel	Exfiltration	AA23-158A and AA23-347A tables	Source	[31][82]
T1567	Exfiltration Over Web Service	Exfiltration	AA23-347A table	Source	[82]
T1486	Data Encrypted for Impact	Impact	ESXiArgs, Royal, LockBit 3.0, AvosLocker, Rhysida, Play and the DISH ransomware attack	Behavior	[6][11][13][71][76][84][9]
T1491.001	Defacement: Internal Defacement	Impact	AA23-335A table	Source	[79]
T1499	Endpoint Denial of Service	Impact	AA23-335A table	Source	[79]
T1499.002	Endpoint Denial of Service: Service Exhaustion Flood	Impact	Storm-1359's layer 7 DDoS (Jun) and HTTP/2 Rapid Reset (from 25 Aug)	Behavior	[33][48][49]
T1531	Account Access Removal	Impact	AA23-335A table	Source	[79]
T1565.001	Data Manipulation: Stored Data Manipulation	Impact	AA23-335A table	Source	[79]
T1657	Financial Theft	Impact	The refund scam (AA23-025A) and the Horizon bridge theft (FBI, 23 Jan)	Behavior	[1][5]

Ids the record mentions but this study leaves out. From AA23-320A, whose live page carries the 2025 revision, this study keeps only the rows for behavior the 2023 record describes: help-desk voice phishing and impersonation (T1598.004, T1566.004, T1684.001), MFA fatigue (T1621) and remote access tools (T1219, named in the 2023 mitigations). The advisory's other rows, T1530, T1078.002, T1199, T1556.006, T1484.002, T1578.002, T1021.007, T1213.002, T1213.003, T1114, T1567, T1567.002, T1552.001, T1552.004, T1606, T1486 and T1657, are not dated to 2023 on its authority, though several appear in the table on other sources (Confirmed [77]; Inferred for the decision). Its mobile ids, T1660 Phishing and T1451 SIM Card Swap, have no Enterprise page in the library and are not in the layer (Demonstrated [137]). The live ATT&CK G1017 page lists T1003.003 and T1047 but not T1090.002 or T1110.003; those two stay in the table on the strength of AA23-144A (Confirmed [130][28]). AA23-193A lists no ATT&CK ids, and Microsoft's Storm-0558 analysis lists none, which is why the Storm-0558 rows are Inferred (Confirmed [37][36]).

ATT&CK for ICS techniques

Id	Name	Tactic (v20.0)	Where it appears in the 2023 record	Basis	Source
T0883	Internet Accessible Device	Initial Access	ATT&CK G1027 page, Unitronics activity (campaign C0031, Nov 2023)	Source	[131]
T1694.001	Insecure Credentials: Default Credentials	Persistence, Lateral Movement	ATT&CK G1027 page, the Unitronics default password	Source	[131]
T0814	Denial of Service	Inhibit Response Function	ATT&CK G1027 page, Unitronics activity	Source	[131]
T0826	Loss of Availability	Impact	ATT&CK G1027 page, Unitronics activity	Source	[131]
T0828	Loss of Productivity and Revenue	Impact	ATT&CK G1027 page, Unitronics activity	Source	[131]
T0829	Loss of View	Impact	ATT&CK G1027 page, Unitronics activity	Source	[131]
T0847	Replication Through Removable Media	Initial Access	Mandiant's Sandworm OT report (published 9 Nov 2023, event Oct 2022)	Source	[75]
T0871	Execution through API	Execution	Mandiant's Sandworm OT report	Source	[75]
T0872	Indicator Removal on Host	Evasion	Mandiant's Sandworm OT report	Source	[75]
T1692.001	Unauthorized Message: Command Message	Evasion, Impair Process Control	Mandiant printed T0855 Unauthorized Command Message, revoked into T1692.001	Source	[75][134]
T0809	Data Destruction	Inhibit Response Function	Mandiant's Sandworm OT report	Source	[75]
T0831	Manipulation of Control	Impact	Mandiant's Sandworm OT report	Source	[75]

That is 12 ICS rows. Mandiant's report also printed T0807 Command-Line Interface and T0853 Scripting, which are deprecated in the library's data with no successor and stay out (Demonstrated [134]). AA23-335A maps Enterprise ids only; the ICS rows for CyberAv3ngers come from ATT&CK's own G1027 page, whose other techniques belong to its 2026 campaign C0065 and are left out (Confirmed [79][131]). The library has no generated ATT&CK for ICS technique pages, no G1027 group page and no C0031 campaign, so these ids are

not linked (Demonstrated [137]).

ATT&CK groups, software and campaigns

Object	Id and library page	Tie to the 2023 record	Source
Volt Typhoon	G1017	AA23-144A and Microsoft (24 May); group created 27 Jul 2023	[28][29][130]
KV Botnet Activity	C0035	Listed on the live G1017 page (Oct 2022 to Jan 2024); its primaries were not opened, so it is named, not bound to an event	[130][137]
TA505	G0092	CISA names CL0P as TA505 (AA23-158A)	[31]
Clop	S0611	MOVEit and GoAnywhere campaigns	[31]
APT29	G0016	SVR TeamCity exploitation (AA23-347A); Midnight Blizzard alias (Teams, Aug; Microsoft, late Nov)	[82][94][86][137]
Star Blizzard	G1033	AA23-341A (7 Dec); SEABORGIUM and COLDRIVER are library aliases, and AA23-341A also names Callisto	[81][137]
Turla	G0010	Snake, FSB Center 16 (AA23-129A)	[22]
Uroburos	S0022	Snake alias; in development since late 2003	[22][137]
APT28	G0007	Jaguar Tooth on Cisco routers (18 Apr)	[90]
Sandworm Team	G0034	Ukrainian substation outage, disclosed 9 Nov	[75]
2022 Ukraine Electric Power Attack	C0034	The event Mandiant disclosed in 2023	[75][137]
CaddyWiper	S0693	New variant on 12 Oct 2022, disclosed 2023	[75]
BlackTech	G0098	AA23-270A (27 Sep)	[60]
UNC3886	G1048	VMware Tools CVE-2023-20867 (13 Jun)	[91][116]
Lazarus Group	G0032	Horizon bridge theft (FBI, 23 Jan)	[5]
APT38	G0082	Named with Lazarus Group by the FBI	[5]
AppleJeus	G1049	UNC4736 alias; 3CX	[17][137]
3CX Supply Chain Attack	C0057	Nov 2022 to Mar 2023	[132][137]
Kimsuky	G0094	CSA-20230601-1 (1 Jun); OFAC designation (30 Nov)	[92][93]
APT33	G0064	Peach Sandstorm alias; password spraying (Feb to Jul)	[95][137]
Scattered Spider	G1015	AA23-320A (16 Nov)	[77]
Play	G1040	AA23-352A (18 Dec)	[84]
Playcrypt	S1162	Play's ransomware	[84][137]
LockBit 3.0	S1202	AA23-075A; Citrix Bleed (AA23-325A); LockBit Black alias	[13][70]

Object	Id and library page	Tie to the 2023 record	Source
LockBit 2.0	S1199	Part of the LockBit totals since 2020 (AA23-165A; binding Inferred)	[34]
BlackCat	S1068	ALPHV alias; AA23-353A; among IC3's top critical infrastructure variants	[85][120]
Royal	S1073	AA23-061A; renamed BlackSuit	[11]
AvosLocker	S1053	AA23-284A	[71]
QakBot	S0650	Infrastructure taken over 25 Aug	[51][52]
TrickBot	S0266	Sanctions on 18 members (Feb, Sep)	[97][101]
Conti	S0575	Trickbot and Conti indictments, per Treasury	[101]
Ragnar Locker	S0481	Taken down 16 to 20 Oct	[100]
Babuk	S0638	Matveev designation (16 May)	[99]
Akira	G1024	Among IC3's top critical infrastructure variants	[120]
Akira	S1129	The ransomware software object; IC3 names Akira as a ransomware variant	[120][137]
Black Basta	S1070	Among IC3's top critical infrastructure variants	[120]

That is 36 objects with library pages, plus two ATT&CK objects with no library page, CyberAv3ngers (G1027) and its campaign C0031, and three vendor clusters with no ATT&CK object, Storm-0558, UNC4841 and UNC4899 (Demonstrated [137]). No ATT&CK object in the library covers Storm-0558, UNC4841, UNC4899, Storm-1359, Maui, H0lyGh0st, ESXiArgs, Bl00dy, BianLian, Truebot, LEMURLOOT, Snatch, Rhysida, Hive, Jaguar Tooth, Pegasus or the Barracuda malware families (Demonstrated [137]). The library's C0046 ArcaneDoor (July 2023 to April 2024), C0029 Cutting Edge (December 2023 to February 2024) and C0045 ShadowRay (September 2023 to March 2024) overlap the year, but their primaries were not opened, so none is bound (Demonstrated [137]). The CVE-2023-23397 exploitation is not bound to APT28 because Microsoft's post names only a Russia-based actor (Confirmed [12]).

CWE and CAPEC

Weakness	CVEs in this record	CAPEC in the library	Source
CWE-89 Improper Neutralization of Special Elements used in an SQL Command	CVE-2023-34362 (MOVEit; NVD and CNA)	CAPEC-66, CAPEC-7, CAPEC-108, CAPEC-109, CAPEC-110, CAPEC-470	[104][139]
CWE-502 Deserialization of Untrusted Data	CVE-2023-0669 (GoAnywhere); CVE-2023-46604 (ActiveMQ); CVE-2021-44228 (AA24-317A)	CAPEC-586 Object Injection	[103][114][115][139]
CWE-77 Improper Neutralization of Special Elements used in a Command	CVE-2023-2868 (Barracuda; NVD)	CAPEC-248 Command Injection, one of eight the library relates; the pick is this study's (Inferred)	[108][139]
CWE-20 Improper Input Validation	CVE-2023-2868 (CNA); CVE-2023-22515 and CVE-2023-23397 (AA24-317A)	Many related CAPEC in the library; none is a clear fit, so none is bound	[108][115][139]
CWE-94 Improper Control of Generation of Code	CVE-2023-3519 (NetScaler)	CAPEC-242, CAPEC-35, CAPEC-77	[109][139]
CWE-119 Improper Restriction of Operations within the Bounds of a Memory Buffer	CVE-2023-4966 (Citrix Bleed; CNA)	Many related CAPEC; none bound	[105][139]
CWE-288 Authentication Bypass Using an Alternate Path or Channel	CVE-2023-42793 (TeamCity; CNA)	CAPEC-127, CAPEC-665	[106][139]
CWE-306 Missing Authentication for Critical Functionality	CVE-2023-42793 (TeamCity; NVD)	CAPEC-12, CAPEC-166, CAPEC-216, CAPEC-36, CAPEC-62	[106][139]
CWE-287 Improper Authentication	CVE-2023-35078 (Ivanti EPMM)	CAPEC-115 Authentication Bypass, one of several the library relates; the pick is this study's (Inferred)	[110][139]
CWE-284 Improper Access Control	CVE-2023-27350 (PaperCut; CNA)	Many related CAPEC; none bound	[111][139]
CWE-863 Incorrect Authorization	CVE-2023-22518 (Confluence)	None in the library	[113][139]
CWE-420 Unprotected Alternate Channel	CVE-2023-20198 (Cisco IOS XE; CNA)	None in the library	[107][139]
CWE-78 Improper Neutralization of Special Elements used in an OS Command	CVE-2023-20273 (AA24-317A)	CAPEC-88 OS Command Injection, one of five the library relates; the pick is this study's (Inferred)	[115][139]

Weakness	CVEs in this record	CAPEC in the library	Source
CWE-122 Heap-based Buffer Overflow	CVE-2023-27997 (FortiOS; KEV and AA24-317A, with CWE-787)	CAPEC-92, as the library relates it	[89][115][139]
CWE-400 Uncontrolled Resource Consumption	CVE-2023-44487 (Rapid Reset; CNA)	CAPEC-147, CAPEC-227, CAPEC-492	[112][139]
CWE-1392 Use of Default Credentials	No CVE: the Unitronics compromises (behavior)	None in the library	[79][139]
CWE-347 Improper Verification of Cryptographic Signature	No CVE: the Storm-0558 token validation flaw (mapping Inferred)	CAPEC-463, CAPEC-475, as the library relates them	[36][139]
NVD-CWE-noinfo	CVE-2023-29059 (3CX)	n/a	[19]

AA24-317A also lists CWE-294 for CVE-2023-23397 and CWE-200 for CVE-2023-49103 (Confirmed [115]); both are in the library's CWE data. The library has no generated CWE pages; the CWE Reference and CAPEC Reference cover the classes.

D3FEND countermeasures

Countermeasure	The library's mappings to this study's techniques (`technique_to_d3fend.json`)	2023 guidance it matches	Source
Multi-factor Authentication (D3-MFA)	T1539, T1606, T1003.003, T1110.003, T1550.001, T1550.004	Phishing-resistant MFA in AA23-158A, AA23-320A and AA23-353A	[138][31][77][85]
Authentication Cache Invalidation (D3-ANCI)	T1539, T1606, T1003.003, T1110.003, T1550.001, T1550.004	Killing active and persistent NetScaler sessions after Citrix Bleed	[138][69]
Session Termination (D3-ST)	T1133, T1199	Ending sessions after Citrix Bleed and the Okta HAR files (pairing Inferred; the library does not bind it to T1539)	[138][69][65]
Credential Revocation (D3-CR)	T1539, T1606, T1550.001	Microsoft revoking all MSA signing keys on 29 Jun (pairing Inferred)	[138][36]
Credential Rotation (D3-CRO)	T1539, T1606, T1110.003	CircleCI's rotate-all-secrets instruction; JumpCloud's forced admin API key rotation	[138][102][42]
Token Binding (D3-TB)	T1550.001	Replayed Storm-0558 tokens (pairing Inferred)	[138][36]
Change Default Password (D3-CDP)	T1078, T1078.001, T1110.003, T1136.001	Replace default PLC passwords (AA23-335A)	[138][79]
Strong Password Policy (D3-SPP)	T1110.003	NIST-aligned passwords (AA23-320A); password spraying by Peach Sandstorm and Midnight Blizzard	[138][77][95][86]
Account Locking (D3-AL)	T1078, T1078.001, T1136	Leftover CL0P admin accounts on rebuilt MOVEit servers (AA23-158A)	[138][31]
Local Account Monitoring (D3-LAM)	T1136.001	New privileged local accounts on Cisco IOS XE (pairing Inferred)	[138][62]
Web Session Access Mediation (D3-WSAM)	T1621	MFA fatigue in AA23-320A	[138][77]
Process Spawn Analysis (D3-PSA)	T1047, T1505.003, T1621	Watching for ntdsutil process creation (AA23-144A)	[138][28]
Executable Allowlisting (D3-EAL)	T1047, T1505.003	Application allowlisting and allowlisting of remote access tools (AA23-158A, AA23-320A); the library does not bind it to T1219 (pairing Inferred)	[138][31][77]
Database Query String Analysis (D3-DQSA)	T1190	The MOVEit SQL injection	[138][104]

Countermeasure	The library's mappings to this study's techniques (technique_to_d3fend.json)	2023 guidance it matches	Source
Inbound Traffic Filtering (D3-ITF)	T1190, T1499.002	Rapid Reset and layer 7 DDoS mitigation by Cloudflare, Google and AWS (pairing Inferred)	[138][48][49][50]
Network Traffic Filtering (D3-NTF)	T1190, T1199, T1219, T1090.002, T1110.003	Segmentation that stopped the NetScaler intruders reaching a domain controller (AA23-201A); OT segmentation (AA23-335A)	[138][44][79]
Remote Terminal Session Detection (D3-RTSD)	T1190, T1219, T1110.004	Unexpected RMM sessions in the refund scam (pairing Inferred)	[138][1]
User Geolocation Logon Pattern Analysis (D3-UGLPA)	T1190, T1219, T1110.004, T1550.004	Credential stuffing at 23andMe; reused Okta sessions (pairing Inferred)	[138][66][65]
Restore File (D3-RF)	T1486, T1505.003, T1565.001	Offline immutable backups (AA23-158A, AA23-320A); backups of PLC logic (AA23-335A)	[138][31][77][79]
Software Update (D3-SU)	T1195.002	KEV-first patching in the 2023 advisories; the library does not bind it to T1190	[138][31]
Asset Vulnerability Enumeration (D3-AVE)	T1195.002	Knowing which edge appliances and file-transfer servers are exposed (pairing Inferred)	[138][115]

Gaps in the library's map: it binds no D3FEND countermeasure to T1556.006, T1598.004 or T1566.004, though AA23-320A's controls, phishing-resistant MFA and help-desk verification, are aimed at exactly those techniques; it does not bind Multi-factor Authentication to T1621 or Session Termination to T1539 (Demonstrated [138]; Inferred for the reading).

Navigator layers

The study's Enterprise techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/chronicle-2023.json, and the ICS rows as navigator/case-studies/chronicle-2023-ics.json, both listed on the Navigator layers page. Open the Enterprise layer in the ATT&CK Navigator. Both are pinned to ATT&CK v20 and are checked against the library's technique profiles by the repository's `scripts/validate_navigator.py` gate. Scores show the basis, not severity: 100 where an opened source prints the id, 70 where the source describes the behavior and this study assigns the id, and 40 for an Inferred mapping. Each entry's comment names the event, the date and the source numbers above, and each technique is shown under every tactic it has in v20.0.

Cross-cutting themes

- **Edge and file-transfer appliances were the main way in (Inferred).** MOVEit, GoAnywhere, Barracuda ESG, NetScaler, Cisco IOS XE, Ivanti EPMM and TeamCity all sat on the internet edge, and five of the top six on AA24-317A are edge or file-transfer products (Confirmed [115]; Inferred for the theme). See Edge Device Security.
- **Identity and sessions beat patching (Inferred).** Citrix Bleed sessions survived the patch, Storm-0558 forged tokens, and Scattered Spider and ALPHV affiliates worked help desks and MFA prompts (Confirmed [69][36][77][85]). The controls that mattered were phishing-resistant MFA, session and credential revocation and allowlisting of remote access tools (Inferred; D3FEND rows in Part 13).
- **Logging was the deciding detection control (Inferred).** Storm-0558 was found only through a paid-tier mailbox access log, and the Volt Typhoon guidance relies on event logs and central log forwarding (Confirmed [39][28]).
- **For edge appliances, the official remedy became assume compromise, then replace or reimage (Inferred).** Barracuda's replacement order, AA23-325A's reimage guidance and AA23-347A's assume-compromise guidance say so in three different products (Confirmed [26][70][82]).
- **Default credentials still opened OT (Inferred).** CyberAv3ngers needed no exploit; CWE-1392 is in the library's data with no CAPEC, and D3FEND's Change Default Password is bound to T1078.001 (Confirmed [79]; Demonstrated [139][138]).
- **Attribution strength varies, and the words matter (Inferred).** The year's attributions run from "PRC state-sponsored" to "suspected North Korean nexus"; edge devices (ESG, Cisco, Fortinet, ESXi) were the common entry point for several of them (Confirmed [28][60][27][17][81][91]). See Threat Actors and Malware Families.

What is overstated and what is understated

- **Overstated: advisory ATT&CK tables as complete.** They are v13 and v14 snapshots that carry ids now revoked in v20 (T1574.002, T1070.001, T1562.001, T1656), and AA23-320A, AA23-335A and AA23-353A were revised in 2024 and 2025, so their live text mixes later behavior into 2023 (Demonstrated [134]; Confirmed [77][79][85]; Inferred for the reading).
- **Overstated: dollar figures read as 2023 losses.** MGM's US$100 million is an estimated hit to Adjusted Property EBITDAR, not a ransom or a total cost, CISA's LockBit totals run from 2020, and Chainalysis revises its own estimates upward (Confirmed [57][34]; Reported [88]; Inferred for the reading).
- **Overstated: actor names for the casino attacks.** The primary filings name no actor and the Scattered Spider advisory names no victim; the MGM link rests on a secondary source, and no source opened links Caesars to any actor (Confirmed [56][57][77]; Reported [88]).
- **Overstated: the crash-dump story for Storm-0558.** Microsoft called it the most probable mechanism, then said in 2024 that it had not found a crash dump containing the key; the CSRB says Microsoft does not know how the key was taken (Confirmed [38][39]).
- **Understated: ransomware money.** IC3's US$59.6 million in adjusted ransomware losses against Chainalysis's estimate of over US$1 billion in payments shows the reported-loss record is a floor, which IC3 itself acknowledges (Confirmed [120]; Reported [88]; Inferred for the comparison).

- **Understated: intrusions at the cloud provider.** Only a customer paying for premium logging could see Storm-0558, and victims without it had no history, so cloud identity intrusions are under-detected by design (Confirmed [39]; Inferred for the reading).
- **Understated: dwell time for stealthy actors.** M-Trends' 10-day median is pulled down by fast ransomware, while Barracuda ESG exploitation ran from October 2022 to May 2023 and Volt Typhoon's living off the land aims at long-term persistence (Reported [118]; Confirmed [25][28]; Inferred for the reading).
- **Understated: the effect of single campaigns on the year's metrics.** The DBIR's 180% rise in exploitation is driven heavily by one campaign, MOVEit (Reported [119]; Inferred for the reading).

Discrepancies in the record

- **Storm-0558's victim count.** Microsoft said about 25 organizations in July; the CSRB counts 22 organizations and over 500 individuals (Confirmed [35][39]).
- **The date of the State Department's report.** Microsoft dates the customer report to 16 June; the CSRB has State's alert firing on 15 June and State contacting Microsoft on 16 June (Confirmed [35][39]).
- **The moved Microsoft address.** The Storm-0558 post of 11 July at its original address, `https://msrc.microsoft.com/blog/2023/07/microsoft-mitigates-china-based-threat-actor-storm-0558-targeting-of-customer-email/`, now redirects to the MSRC blog index; this study cites the copy at microsoft.com [35] (Confirmed [133]).
- **Barracuda's dates.** Barracuda identified the flaw on 19 May; Mandiant gives 23 May as the day Barracuda announced it (Confirmed [26][27]).
- **CVE-2023-2868's weakness.** The CNA gives CWE-20; NVD gives CWE-77 (Confirmed [108]).
- **CVE-2023-42793's weakness.** The CNA gives CWE-288; NVD gives CWE-306 (Confirmed [106]).
- **CVE-2023-4966's weakness.** The CNA gives CWE-119; NVD gives NVD-CWE-noinfo (Confirmed [105]).
- **3CX's attribution confidence.** 3CX's relay of Mandiant's interim results says Mandiant assessed a North Korean nexus with high confidence; Mandiant's own post of 20 April calls UNC4736 a suspected North Korean nexus cluster and links it to AppleJeus with moderate confidence (Reported [16]; Confirmed [17]).
- **Microsoft's storage exposure size.** The 38 TB figure is not on Microsoft's page (Confirmed [58]).
- **Royal's name.** AA23-061A was published for Royal and renamed BlackSuit in the August 2024 update; the library's object is still Royal (Confirmed [11]; Demonstrated [137]).

Sources

All sources were opened on 11 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here. Addresses shown as code rather than as links refuse automated link checkers (the SEC's filings and press releases, Fortra's investigation summary and LastPass's update); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	CISA, AA23-025A, Protecting against malicious use of remote monitoring and management software, 25 Jan 2023	cisa.gov	2026-11-11	Confirmed
2	T-Mobile US, Form 8-K, filed 19 Jan 2023	https://www.sec.gov/Archives/edgar/data/1283699/000119312523010949/d641142d8k.htm	2026-11-11	Confirmed
3	CISA, FBI and MS-ISAC, AA23-074A, Telerik vulnerability exploited at a federal agency IIS server (last revised 15 Jun 2023)	cisa.gov	2026-11-11	Confirmed
4	Fortra, summary of the investigation related to CVE-2023-0669	https://www.fortra.com/blog/summary-investigation-related-cve-2023-0669	2026-11-11	Confirmed
5	FBI, FBI confirms Lazarus Group cyber actors responsible for Harmony's Horizon bridge currency theft, 23 Jan 2023, updated 6 Feb 2023	fbi.gov	2026-11-11	Confirmed
6	CISA and FBI, AA23-039A, ESXiArgs ransomware virtual machine recovery guidance, 8 Feb 2023	cisa.gov	2026-11-11	Confirmed
7	CISA, CISA releases ESXiArgs ransomware recovery script, 7 Feb 2023	cisa.gov	2026-11-11	Confirmed
8	CISA, FBI, NSA and partners, AA23-040A, DPRK ransomware against healthcare and critical infrastructure, 9 Feb 2023	cisa.gov	2026-11-11	Confirmed
9	DISH Network, Form 8-K, filed 28 Feb 2023	https://www.sec.gov/Archives/edgar/data/1001082/000155837023002254/dish-20230223x8k.htm	2026-11-11	Confirmed
10	LastPass, security incident update and recommended actions, 1 Mar 2023	https://blog.lastpass.com/posts/2023/03/security-incident-update-recommended-actions	2026-11-11	Confirmed
11	CISA and FBI, AA23-061A, Royal ransomware (2 Mar 2023; updated 13 Nov 2023 and Aug 2024)	cisa.gov	2026-11-11	Confirmed
12	Microsoft MSRC, Microsoft mitigates Outlook elevation of privilege vulnerability, 14 Mar 2023	microsoft.com	2026-11-11	Confirmed
13	CISA, FBI and MS-ISAC, AA23-075A, LockBit 3.0, 16 Mar 2023	cisa.gov	2026-11-11	Confirmed
14	Latitude Financial, Latitude cyber incident	latitudefinancial.com.au	2026-11-11	Confirmed
15	3CX, Desktop App security alert, 30 Mar 2023	3cx.com	2026-11-11	Confirmed
16	3CX, Mandiant initial results, Apr 2023	3cx.com	2026-11-11	Reported

#	Source	URL	Opened	Grade
17	Mandiant (Google Cloud), 3CX software supply chain compromise initiated by a prior software supply chain compromise, 20 Apr 2023	cloud.google.com	2026-11-11	Confirmed
18	CISA, Supply chain attack against 3CXDesktopApp, 30 Mar 2023	cisa.gov	2026-11-11	Confirmed
19	NVD, CVE-2023-29059	nvd.nist.gov	2026-11-11	Confirmed
20	Western Digital, Western Digital provides information on network security incident, 2 Apr 2023	westerndigital.com	2026-11-11	Confirmed
21	FBI and CISA, AA23-131A, PaperCut CVE-2023-27350 exploitation, 11 May 2023	cisa.gov	2026-11-11	Confirmed
22	CISA and partners, AA23-129A, Hunting Russian intelligence Snake malware, 9 May 2023	cisa.gov	2026-11-11	Confirmed
23	SektorCERT, The attack against Danish critical infrastructure (TLP:CLEAR), Nov 2023	sektorcert.dk	2026-11-11	Confirmed
24	CISA, FBI and ACSC, AA23-136A, BianLian ransomware (May 2023; updated 20 Nov 2024)	cisa.gov	2026-11-11	Confirmed
25	Barracuda, ESG vulnerability (legal page)	barracuda.com	2026-11-11	Confirmed
26	Barracuda, ESG vulnerability (trust center)	trust.barracuda.com	2026-11-11	Confirmed
27	Mandiant (Google Cloud), Barracuda ESG zero-day vulnerability exploited globally by suspected China-nexus actor, 15 Jun 2023	cloud.google.com	2026-11-11	Confirmed
28	NSA, CISA, FBI and partners, AA23-144A, PRC state-sponsored actor living off the land, 24 May 2023	cisa.gov	2026-11-11	Confirmed
29	Microsoft Security, Volt Typhoon targets US critical infrastructure with living-off-the-land techniques, 24 May 2023	microsoft.com	2026-11-11	Confirmed
30	Mandiant (Google Cloud), Zero-day vulnerability in MOVEit Transfer exploited for data theft, Jun 2023	cloud.google.com	2026-11-11	Confirmed
31	CISA and FBI, AA23-158A, CL0P ransomware gang exploits CVE-2023-34362 MOVEit vulnerability, 7 Jun 2023	cisa.gov	2026-11-11	Confirmed
32	Kaspersky Securelist, Operation Triangulation, 1 Jun 2023	securelist.com	2026-11-11	Confirmed
33	Microsoft MSRC, Microsoft response to layer 7 DDoS attacks, 16 Jun 2023	microsoft.com	2026-11-11	Confirmed
34	CISA and partners, AA23-165A, Understanding LockBit, 14 Jun 2023	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
35	Microsoft MSRC, Microsoft mitigates China-based threat actor Storm-0558 targeting of customer email, 11 Jul 2023	microsoft.com	2026-11-11	Confirmed
36	Microsoft Security, Analysis of Storm-0558 techniques for unauthorized email access, 14 Jul 2023	microsoft.com	2026-11-11	Confirmed
37	CISA and FBI, AA23-193A, Enhanced monitoring to detect APT activity targeting Outlook Online, 12 Jul 2023	cisa.gov	2026-11-11	Confirmed
38	Microsoft MSRC, Results of major technical investigations for Storm-0558 key acquisition, 6 Sep 2023, with 12 Mar 2024 addendum	microsoft.com	2026-11-11	Confirmed
39	Cyber Safety Review Board, Review of the Summer 2023 Microsoft Exchange Online intrusion, 20 Mar 2024	cisa.gov	2026-11-11	Confirmed
40	CISA, FBI, MS-ISAC and CCCS, AA23-187A, Increased Truebot activity, 6 Jul 2023	cisa.gov	2026-11-11	Confirmed
41	Mandiant (Google Cloud), North Korea uses a SaaS provider in a targeted supply chain attack (title paraphrased), 24 Jul 2023	cloud.google.com	2026-11-11	Confirmed
42	JumpCloud, security update: incident details	jumpcloud.com	2026-11-11	Confirmed
43	Estee Lauder Companies, Form 8-K, filed 19 Jul 2023	`https://www.sec.gov/Archives/edgar/data/1001250/000114036123035105/brhc20056073_8k.htm`	2026-11-11	Confirmed
44	CISA, AA23-201A, Threat actors exploiting Citrix CVE-2023-3519, 20 Jul 2023	cisa.gov	2026-11-11	Confirmed
45	CISA and NCSC-NO, AA23-213A, Ivanti EPMM CVE-2023-35078 and CVE-2023-35081, 1 Aug 2023	cisa.gov	2026-11-11	Confirmed
46	SEC, press release 2023-139, SEC adopts rules on cybersecurity risk management, strategy, governance and incident disclosure, 26 Jul 2023	`https://www.sec.gov/newsroom/press-releases/2023-139`	2026-11-11	Confirmed
47	Clorox, Form 8-K, filed 14 Aug 2023	`https://www.sec.gov/Archives/edgar/data/21076/000120677423000969/clx4231381-8k.htm`	2026-11-11	Confirmed
48	Cloudflare, HTTP/2 Rapid Reset: deconstructing the record-breaking attack, 10 Oct 2023	blog.cloudflare.com	2026-11-11	Confirmed
49	Google Cloud, Google Cloud mitigated largest DDoS attack, peaking above 398 million rps, 10 Oct 2023	cloud.google.com	2026-11-11	Confirmed
50	AWS Security Blog, How AWS protects customers from DDoS events, Oct 2023	aws.amazon.com	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
51	CISA and FBI, AA23-242A, Identification and disruption of QakBot infrastructure, 30 Aug 2023	cisa.gov	2026-11-11	Confirmed
52	FBI, FBI, partners dismantle QakBot infrastructure in multinational cyber takedown, Aug 2023	fbi.gov	2026-11-11	Confirmed
53	Europol, Qakbot botnet infrastructure shattered after international operation, 30 Aug 2023	europol.europa.eu	2026-11-11	Confirmed
54	CISA, FBI and CNMF, AA23-250A, Multiple nation-state actors exploit CVE-2022-47966 and CVE-2022-42475, 7 Sep 2023	cisa.gov	2026-11-11	Confirmed
55	Citizen Lab, BLASTPASS: NSO Group iPhone zero-click, zero-day exploit captured in the wild, 7 Sep 2023	citizenlab.ca	2026-11-11	Confirmed
56	Caesars Entertainment, Form 8-K, filed 14 Sep 2023	`https://www.sec.gov/Archives/edgar/data/1590895/000119312523235015/d537840d8k.htm`	2026-11-11	Confirmed
57	MGM Resorts International, Form 8-K, filed 5 Oct 2023	`https://www.sec.gov/Archives/edgar/data/789570/000119312523251667/d461062d8k.htm`	2026-11-11	Confirmed
58	Microsoft MSRC, Microsoft mitigated exposure of internal information in a storage account due to overly permissive SAS token, 18 Sep 2023	microsoft.com	2026-11-11	Confirmed
59	FBI and CISA, AA23-263A, Snatch ransomware, 20 Sep 2023	cisa.gov	2026-11-11	Confirmed
60	NSA, FBI, CISA, NPA and NISC, AA23-270A, PRC-linked actors hide in router firmware, 27 Sep 2023	cisa.gov	2026-11-11	Confirmed
61	Johnson Controls International, Form 8-K, filed 27 Sep 2023	`https://www.sec.gov/Archives/edgar/data/833444/000083344423000036/jci-20230927.htm`	2026-11-11	Confirmed
62	Cisco, Multiple vulnerabilities in Cisco IOS XE Software web UI feature, first published 16 Oct 2023	sec.cloudapps.cisco.com	2026-11-11	Confirmed
63	Cisco Talos, Active exploitation of Cisco IOS XE Software web management user interface vulnerabilities, Oct 2023	blog.talosintelligence.com	2026-11-11	Confirmed
64	Okta Security, Tracking unauthorized access to Okta's support system, 20 Oct 2023	sec.okta.com	2026-11-11	Confirmed
65	Okta Security, Unauthorized access to Okta's support case management system: root cause and remediation, Nov 2023	sec.okta.com	2026-11-11	Confirmed
66	23andMe, Addressing data security concerns	blog.23andme.com	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
67	23andMe Holding Co., Form 8-K/A, filed 1 Dec 2023	https://www.sec.gov/Archives/edgar/data/1804591/000119312523287449/d242666d8ka.htm	2026-11-11	Confirmed
68	CISA, FBI and MS-ISAC, AA23-289A, Threat actors exploit Atlassian Confluence CVE-2023-22515, 16 Oct 2023	cisa.gov	2026-11-11	Confirmed
69	NetScaler, CVE-2023-4966: critical security update now available for NetScaler ADC and NetScaler Gateway, 10 Oct 2023, updated 23 Oct 2023	netscaler.com	2026-11-11	Confirmed
70	CISA, FBI, MS-ISAC and ACSC, AA23-325A, LockBit 3.0 affiliates exploit Citrix Bleed, 21 Nov 2023	cisa.gov	2026-11-11	Confirmed
71	FBI and CISA, AA23-284A, AvosLocker ransomware, 11 Oct 2023	cisa.gov	2026-11-11	Confirmed
72	British Library, cyber incident page	bl.uk	2026-11-11	Confirmed
73	British Library, Learning lessons from the cyber-attack: British Library cyber incident review, 8 Mar 2024	bl.uk	2026-11-11	Confirmed
74	SEC, press release 2023-227, SEC charges SolarWinds and chief information security officer, 30 Oct 2023	https://www.sec.gov/newsroom/press-releases/2023-227	2026-11-11	Confirmed
75	Mandiant (Google Cloud), Sandworm disrupts power in Ukraine using a novel attack against operational technology, 9 Nov 2023	cloud.google.com	2026-11-11	Confirmed
76	FBI, CISA and MS-ISAC, AA23-319A, Rhysida ransomware, 15 Nov 2023	cisa.gov	2026-11-11	Confirmed
77	FBI and CISA, AA23-320A, Scattered Spider (16 Nov 2023; updated 29 Jul 2025)	cisa.gov	2026-11-11	Confirmed
78	CISA, Exploitation of Unitronics PLCs used in water and wastewater systems, 28 Nov 2023	cisa.gov	2026-11-11	Confirmed
79	FBI, CISA, NSA, EPA, INCD and partners, AA23-335A, IRGC-affiliated actors exploit PLCs (1 Dec 2023; revised 18 Dec 2024)	cisa.gov	2026-11-11	Confirmed
80	CISA, AA23-339A, Threat actors exploit Adobe ColdFusion CVE-2023-26360, 5 Dec 2023	cisa.gov	2026-11-11	Confirmed
81	NCSC-UK and partners, AA23-341A, Russian FSB cyber actor Star Blizzard continues worldwide spear-phishing campaigns, 7 Dec 2023	cisa.gov	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
82	FBI, CISA, NSA, SKW, CERT Polska and NCSC-UK, AA23-347A, Russian SVR exploiting JetBrains TeamCity CVE globally, 13 Dec 2023	cisa.gov	2026-11-11	Confirmed
83	Ledger, letter from the chairman and CEO regarding the Ledger Connect Kit exploit, Dec 2023	ledger.com	2026-11-11	Confirmed
84	FBI, CISA and ASD's ACSC, AA23-352A, Play ransomware, 18 Dec 2023	cisa.gov	2026-11-11	Confirmed
85	FBI, CISA and HHS, AA23-353A, ALPHV Blackcat (19 Dec 2023; updated 27 Feb 2024)	cisa.gov	2026-11-11	Confirmed
86	Microsoft MSRC, Microsoft actions following attack by nation state actor Midnight Blizzard, 19 Jan 2024	microsoft.com	2026-11-11	Confirmed
87	Microsoft Corporation, Form 8-K (Item 1.05), filed 19 Jan 2024	`https://www.sec.gov/Archives/edgar/data/789019/000119312524011295/d708866d8k.htm`	2026-11-11	Confirmed
88	Chainalysis, Ransomware payments exceed $1 billion in 2023, 7 Feb 2024	chainalysis.com	2026-11-11	Reported
89	CISA, Known Exploited Vulnerabilities catalog (JSON feed, catalog version 2026.11.10)	cisa.gov	2026-11-11	Confirmed (counts Demonstrated)
90	CISA, APT28 exploits known vulnerability to carry out reconnaissance and deploy malware on Cisco routers, 18 Apr 2023	cisa.gov	2026-11-11	Confirmed
91	Mandiant (Google Cloud), VMware Tools zero-day exploited by UNC3886, 13 Jun 2023	cloud.google.com	2026-11-11	Confirmed
92	FBI, State Department, NSA and ROK partners, CSA-20230601-1, North Korea using social engineering to enable hacking of think tanks, academia and media, 1 Jun 2023	ic3.gov	2026-11-11	Confirmed
93	US Treasury, press release JY1938, OFAC designation of Kimsuky, 30 Nov 2023	home.treasury.gov	2026-11-11	Confirmed
94	Microsoft Security, Midnight Blizzard conducts targeted social engineering over Microsoft Teams, 2 Aug 2023	microsoft.com	2026-11-11	Confirmed
95	Microsoft Security, Peach Sandstorm password spray campaigns enable intelligence collection at high-value targets, 14 Sep 2023	microsoft.com	2026-11-11	Confirmed
96	Europol, Cybercriminals stung as HIVE infrastructure is shut down, 26 Jan 2023	europol.europa.eu	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
97	US Treasury, press release JY1256, United States and United Kingdom sanction members of Russia-based Trickbot gang, 9 Feb 2023	home.treasury.gov	2026-11-11	Confirmed
98	Europol, Takedown of notorious hacker marketplace selling your identity to criminals (Genesis Market), 5 Apr 2023	europol.europa.eu	2026-11-11	Confirmed
99	US Treasury, press release JY1486, designation of Mikhail Matveev, 16 May 2023	home.treasury.gov	2026-11-11	Confirmed
100	Europol, Ragnar Locker ransomware gang taken down by international police swoop, Oct 2023	europol.europa.eu	2026-11-11	Confirmed
101	US Treasury, press release JY1714, further Trickbot designations with the UK, 7 Sep 2023	home.treasury.gov	2026-11-11	Confirmed
102	CircleCI, CircleCI incident report for January 4, 2023 security incident, 12 Jan 2023	circleci.com	2026-11-11	Confirmed
103	NVD, CVE-2023-0669	nvd.nist.gov	2026-11-11	Confirmed
104	NVD, CVE-2023-34362	nvd.nist.gov	2026-11-11	Confirmed
105	NVD, CVE-2023-4966	nvd.nist.gov	2026-11-11	Confirmed
106	NVD, CVE-2023-42793	nvd.nist.gov	2026-11-11	Confirmed
107	NVD, CVE-2023-20198	nvd.nist.gov	2026-11-11	Confirmed
108	NVD, CVE-2023-2868	nvd.nist.gov	2026-11-11	Confirmed
109	NVD, CVE-2023-3519	nvd.nist.gov	2026-11-11	Confirmed
110	NVD, CVE-2023-35078	nvd.nist.gov	2026-11-11	Confirmed
111	NVD, CVE-2023-27350	nvd.nist.gov	2026-11-11	Confirmed
112	NVD, CVE-2023-44487	nvd.nist.gov	2026-11-11	Confirmed
113	NVD, CVE-2023-22518 record (API)	services.nvd.nist.gov	2026-11-11	Confirmed
114	NVD, CVE-2023-46604 record (API)	services.nvd.nist.gov	2026-11-11	Confirmed
115	CISA and partners, AA24-317A, 2023 Top Routinely Exploited Vulnerabilities, 12 Nov 2024	cisa.gov	2026-11-11	Confirmed
116	Google Threat Intelligence (TAG and Mandiant), A review of zero-day exploitation in 2023, 27 Mar 2024	cloud.google.com	2026-11-11	Confirmed
117	Google, A review of zero-day in-the-wild exploits in 2023, 27 Mar 2024	blog.google	2026-11-11	Reported
118	Mandiant (Google Cloud), M-Trends 2024, 23 Apr 2024	cloud.google.com	2026-11-11	Reported

#	Source	URL	Opened	Grade
119	Verizon, 2024 Data Breach Investigations Report news release, 1 May 2024	verizon.com	2026-11-11	Reported
120	FBI IC3, Internet Crime Report 2023	ic3.gov	2026-11-11	Confirmed
121	European Commission, NIS2 Directive policy page	digital-strategy.ec.europa.eu	2026-11-11	Confirmed
122	The White House (archive), Fact sheet: National Cybersecurity Strategy, 2 Mar 2023	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
123	CISA, CISA establishes Ransomware Vulnerability Warning Pilot program, 13 Mar 2023	cisa.gov	2026-11-11	Confirmed
124	The White House (archive), Fact sheet: executive order to prohibit US government use of commercial spyware that poses risks to national security, 27 Mar 2023	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
125	CISA, Secure by Design	cisa.gov	2026-11-11	Confirmed
126	NIST, NIST drafts major update to its widely used Cybersecurity Framework, 8 Aug 2023	nist.gov	2026-11-11	Confirmed
127	The White House (archive), Executive Order 14110 on safe, secure and trustworthy AI, 30 Oct 2023	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
128	The White House (archive), International Counter Ransomware Initiative 2023 joint statement, 1 Nov 2023	bidenwhitehouse.archives.gov	2026-11-11	Confirmed
129	European Commission, Cyber Resilience Act policy page	digital-strategy.ec.europa.eu	2026-11-11	Confirmed
130	MITRE ATT&CK, group G1017 Volt Typhoon (content v20.1)	attack.mitre.org	2026-11-11	Confirmed
131	MITRE ATT&CK, group G1027 CyberAv3ngers (content v20.1)	attack.mitre.org	2026-11-11	Confirmed
132	MITRE ATT&CK, campaign C0057 3CX Supply Chain Attack (content v20.1)	attack.mitre.org	2026-11-11	Confirmed
133	Microsoft MSRC, original address of the 11 Jul 2023 Storm-0558 post, now redirecting to the blog index (kept as plain text)	`https://msrc.microsoft.com/blog/2023/07/microsoft-mitigates-china-based-threat-actor-storm-0558-targeting-of-customer-email/`	2026-11-11	Confirmed (moved)
134	TeamStarWolf library, `data/attack/superseded_by.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
135	TeamStarWolf library, `data/attack/technique_profiles.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
136	TeamStarWolf library, `data/attack/ics/technique_profiles.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated

#	Source	URL	Opened	Grade
137	TeamStarWolf library, ATT&CK group, software and campaign data (`data/attack/`) and generated pages (`mitre/`)	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
138	TeamStarWolf library, `data/attack/technique_to_d3fend.jsonl` and `data/attack/d3fend_countermeasures.jsonl`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated
139	TeamStarWolf library, `data/weaknesses/cwe.jsonl` and the CAPEC pages under `mitre/capec/`	github.com/TeamStarWolf/TeamStarWolf	2026-11-11	Demonstrated

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Ransomware Defense Reference, Edge Device Security Reference, ICS/OT Security Reference, ICS ATT&CK Atlas, Cloud Attack Reference, Supply Chain Security, Vulnerability Prioritization Reference, Incident Response Reference
- Home studies: The Cl0p MOVEit breach and the file-transfer extortion playbook; Sandworm; China-attributed actors; Russia-attributed actors; North Korea-attributed actors; Iran-attributed actors; Zero-day market events; Log4Shell
- Related studies: The Ransomware Ecosystem; SolarWinds and SUNBURST; Healthcare threat actor watchlist; npm supply-chain attacks; Hugging Face supply chain; Stuxnet; ICS attacks and advisories, 2024 to 2026; APT41: the public record; Exchange Marauder, 2021
- Series: 2016, 2017, 2018, 2019, 2020, 2021, 2022
- Groups: G1017 Volt Typhoon, G0092 TA505, G0016 APT29, G1033 Star Blizzard, G0010 Turla, G0007 APT28, G0034 Sandworm Team, G0098 BlackTech, G1048 UNC3886, G0032 Lazarus Group, G0082 APT38, G1049 AppleJeus, G0094 Kimsuky, G0064 APT33, G1015 Scattered Spider, G1040 Play, G1024 Akira
- Campaigns: C0057 3CX Supply Chain Attack, C0034 2022 Ukraine Electric Power Attack, C0035 KV Botnet Activity

- Software: S0611 Clop, S0022 Uroburos, S0693 CaddyWiper, S1202 LockBit 3.0, S1068 BlackCat, S1073 Royal, S1053 AvosLocker, S1162 Playcrypt, S0650 QakBot, S0266 TrickBot, S0481 Ragnar Locker, S0638 Babuk, S1070 Black Basta, S1129 Akira
- Techniques: T1190 Exploit Public-Facing Application, T1505.003 Web Shell, T1539 Steal Web Session Cookie, T1550.004 Web Session Cookie, T1606 Forge Web Credentials, T1621 Multi-Factor Authentication Request Generation, T1598.004 Spearphishing Voice, T1195.002 Compromise Software Supply Chain, T1110.003 Password Spraying, T1486 Data Encrypted for Impact, T1685 Disable or Modify Tools
- CAPEC: CAPEC-66, CAPEC-586, CAPEC-115, CAPEC-127, CAPEC-147
- Navigator layers, including this study's layers, chronicle-2023.json and chronicle-2023-ics.json